

# The Price of Convenience

How Security Vulnerabilities in Global  
Transportation Payment Systems Can Cost You

 Omer Attias

# Omer Attias

## Security Researcher

- 6 years of experience in cyber security
- Main focus in low level & vulnerability research
- Technology and Science enthusiast



# Agenda

- Introduction
- Mobile Payment Solution
- Train Tickets & Hole In The Logs
- Moovit
- API & Implementation Benefits
- Closure and Q&A

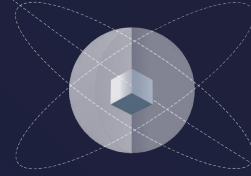
# Public Transportation





# MaaS & MaaS Operator

What is MaaS?



# MaaS & MaaS Operator

**Mobility as a service** (MaaS) is a type of service that enables users to plan, book, and pay for multiple types of mobility services - all in one mobile application.

A **MaaS Operator** is a company that hosts a variety of transport options.



**Bird**



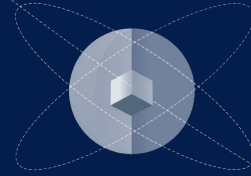
**Moovit**

# Disclosure

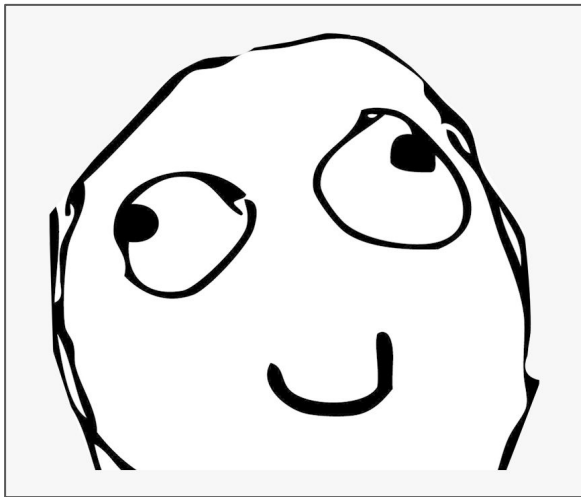




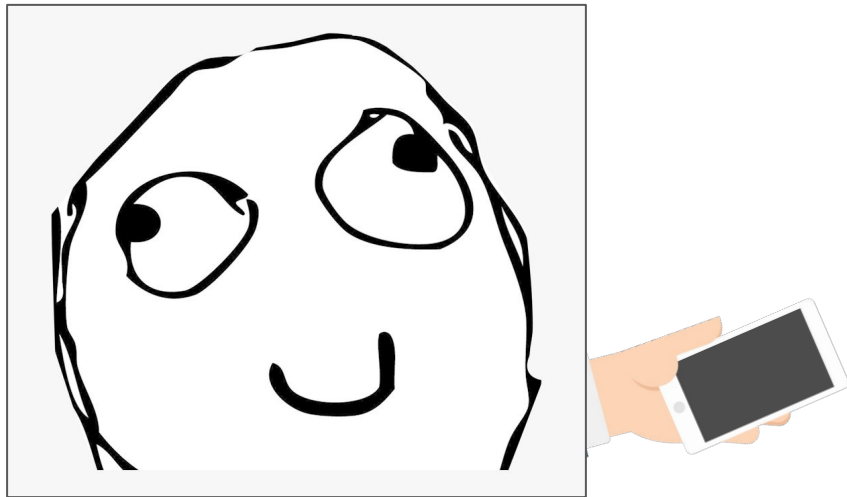
# The Mobile Solution



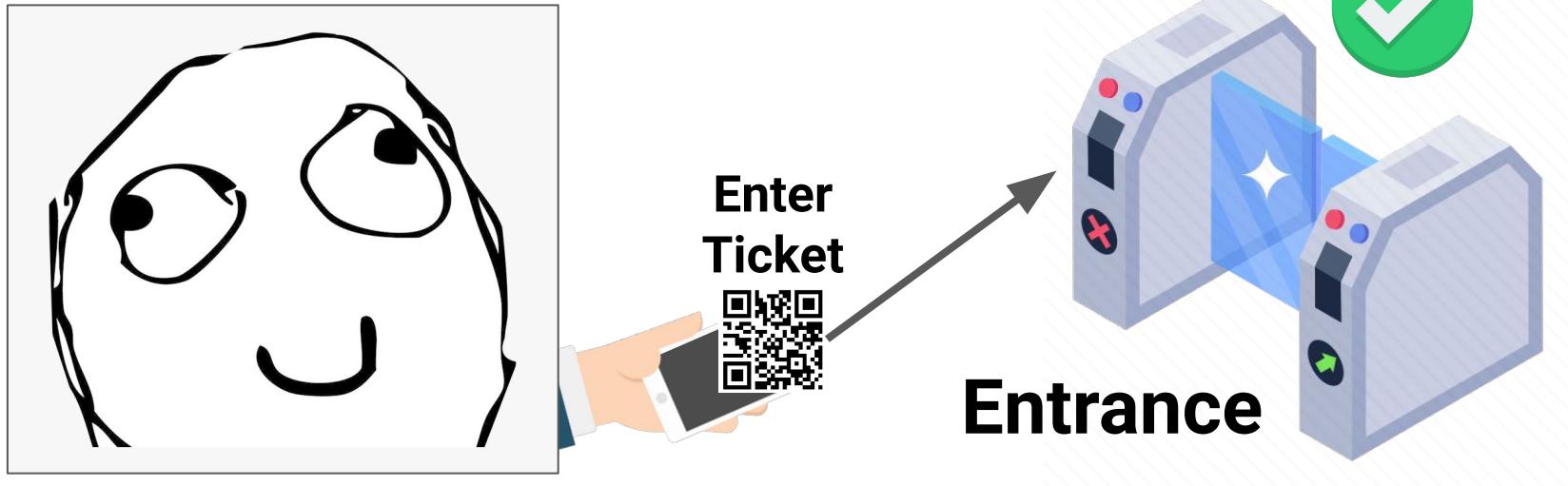
# Meet Mike



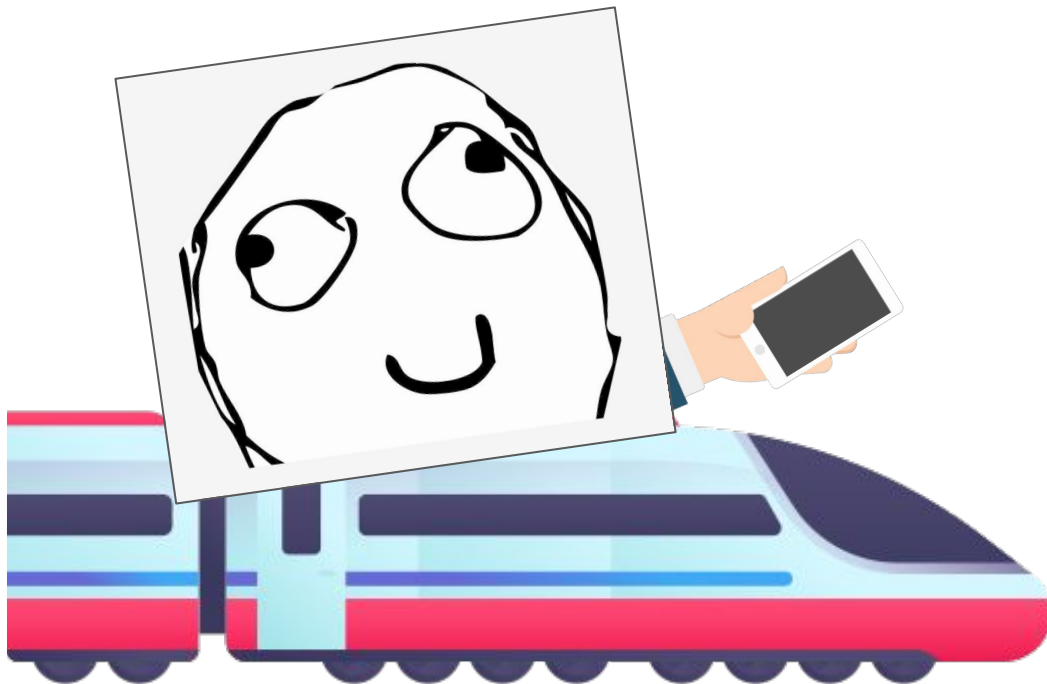
# Paying With The Smartphone



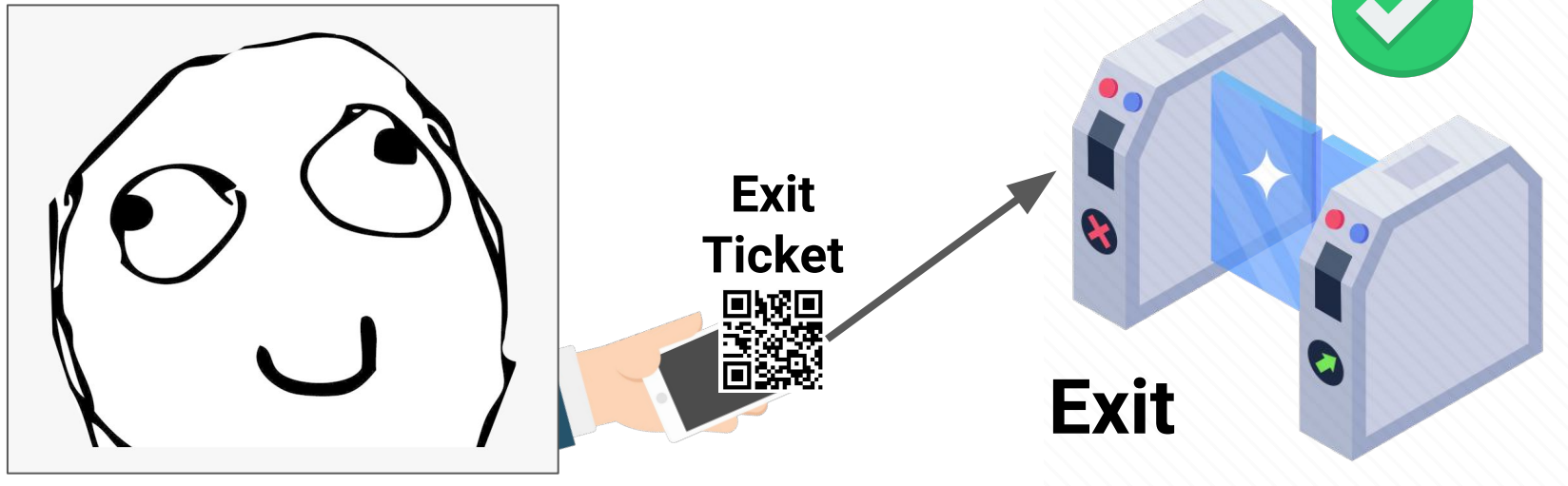
# Entering The Train Station



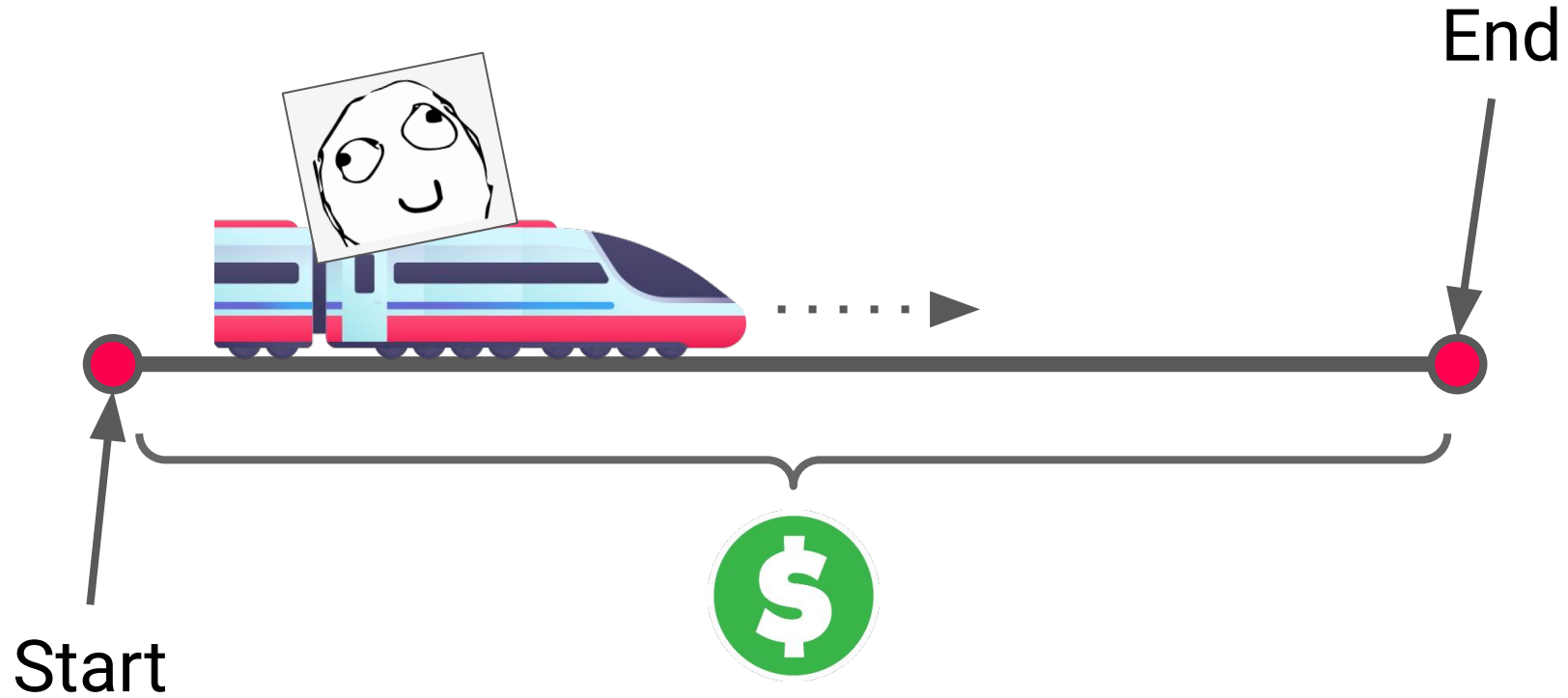
# Having Fun Ride



# Exiting The Train Station



# Fare Calculation

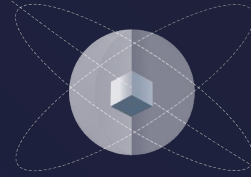


# What The Ticket Contains?





# Ticket Format



# Ticket Example



**1103111228148713604081111039120515963892513201**

# Collecting Samples

#1

Date: 12.06.2022

Entered station: Merkazit Ha-Miphratz Time: 9:01

Exited station: Tel Aviv Ha-Shalom Time: 10:40

Ticket: 10111141113013101317413141310147412123511371101211201

#2

Date: 09.06.2022

Entered Station: Tel Aviv Ha-Shalom Time: 19:31

Exited Station: Merkazit Ha-Miphratz Time: 21:11

Ticket: 115761016221135471289613131514410212114501201

#3

Date: 06.06.2022

Entered Station: Merkazit Ha-Miphratz Time: 08:53

Exited Station: Tel Aviv Ha-Shalom Time: 10:40

Ticket: 101111412714121312412154313121121371384823151294311201

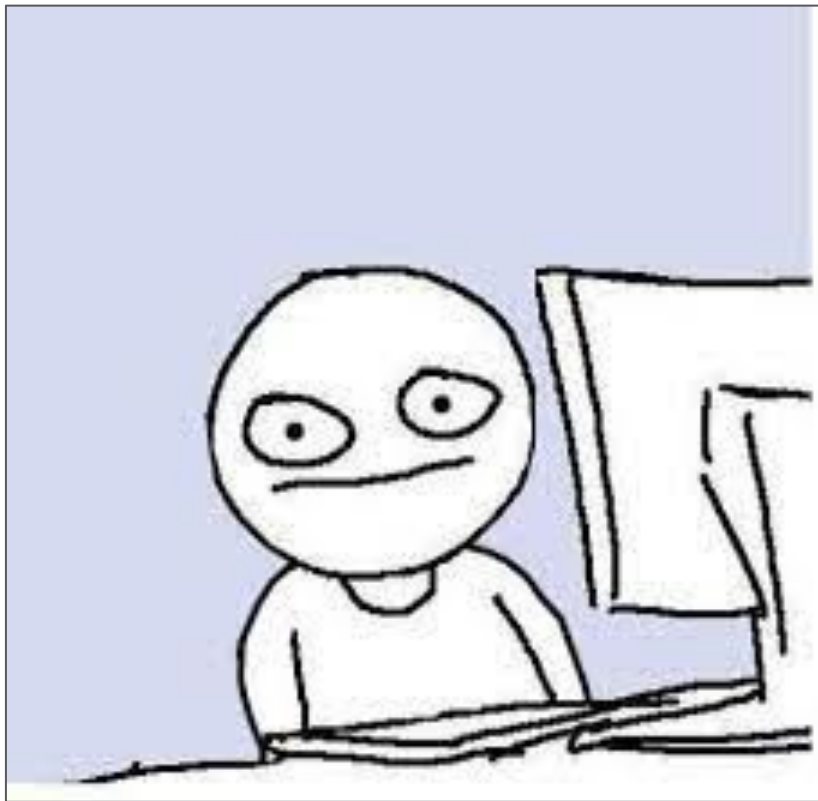
# Quick Search On Google

Found the following API:

**<https://ravkavonline.co.il/api/ravkav/lookups/>**

```
{  
  "operator": [  
    {  
      "id": 200,  
      "name": "HopOn",  
      "hidden": true  
    },  
    {  
      "id": 201,  
      "name": "Moovit-Pango",  
      "hidden": true  
    },  
    ...  
  ],  
  {  
    "id": 250,  
    "name": "IDF",  
    "hidden": true  
  },  
  ]  
}
```

Well.. Now What?



# The Experiment

Valid Ticket:

**1103111228148713604081111039120515963892513201**

Moovit-Pango Operator

To

IDF Operator

Fake Ticket:

**1103111228148713604081111039120515963892513250**



# The Experiment

Valid Ticket:

**1103111228148713604081111039120515963892513201**



Fake Ticket:

**1103111228148713604081111039120515963892513250**

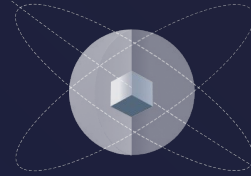
# Conclusion





# The Gates

(Behind the Scenes)

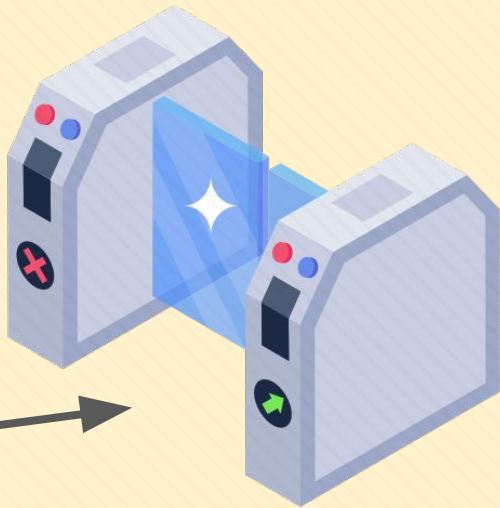


# Logical Vulnerability

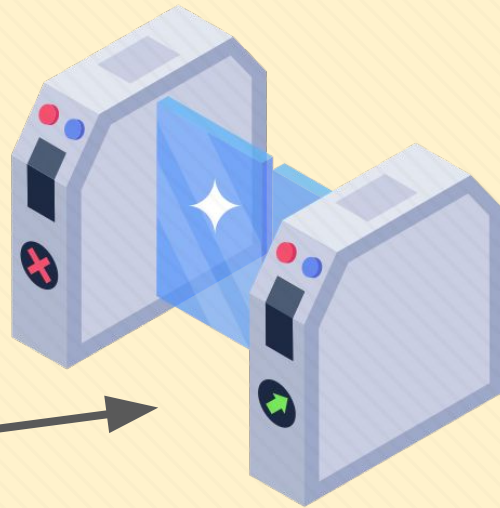


# Reminder

**Enter  
Ticket**



**Exit  
Ticket**



# Diffing Entrance & Exit Tickets

**Enter  
Ticket**

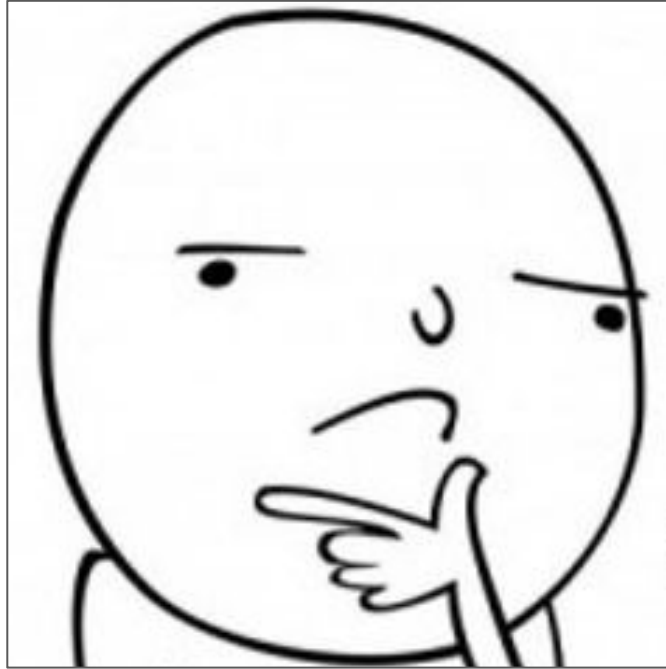


=

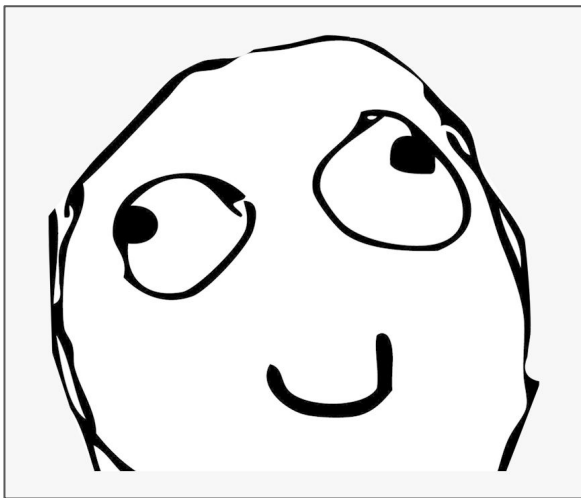
**Exit  
Ticket**



■ Hmm...



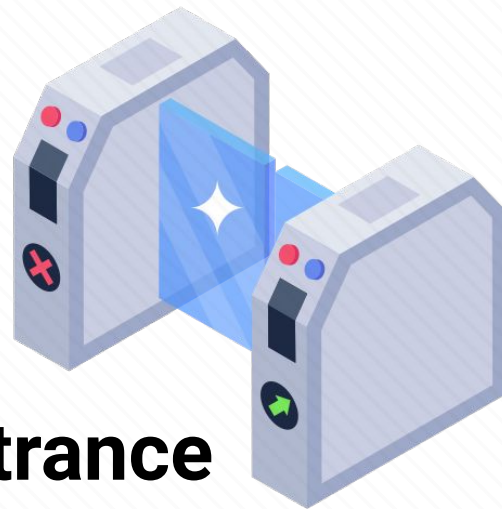
# Cancel & Use



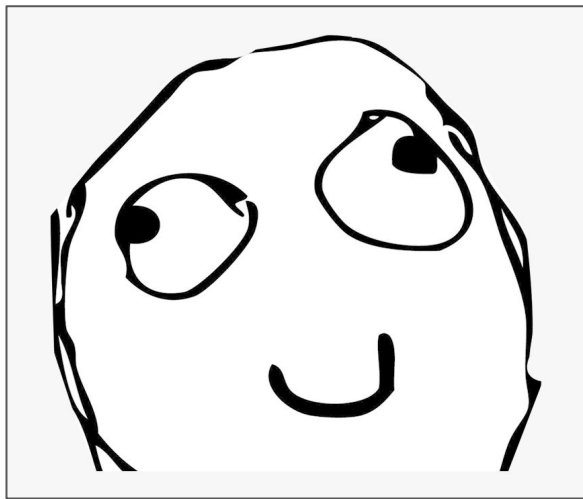
Enter  
Ticket



Entrance



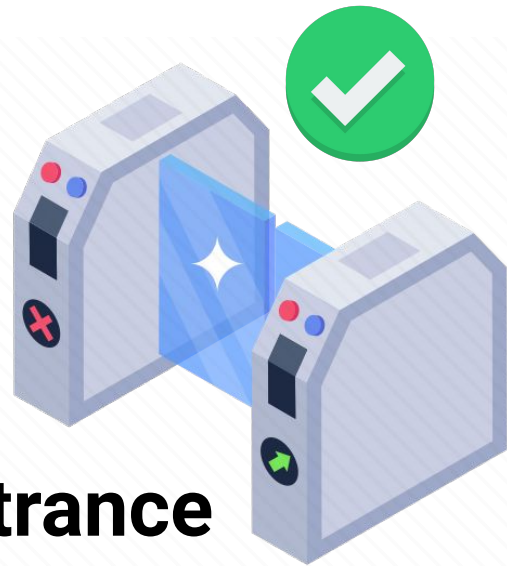
# Cancel & Use



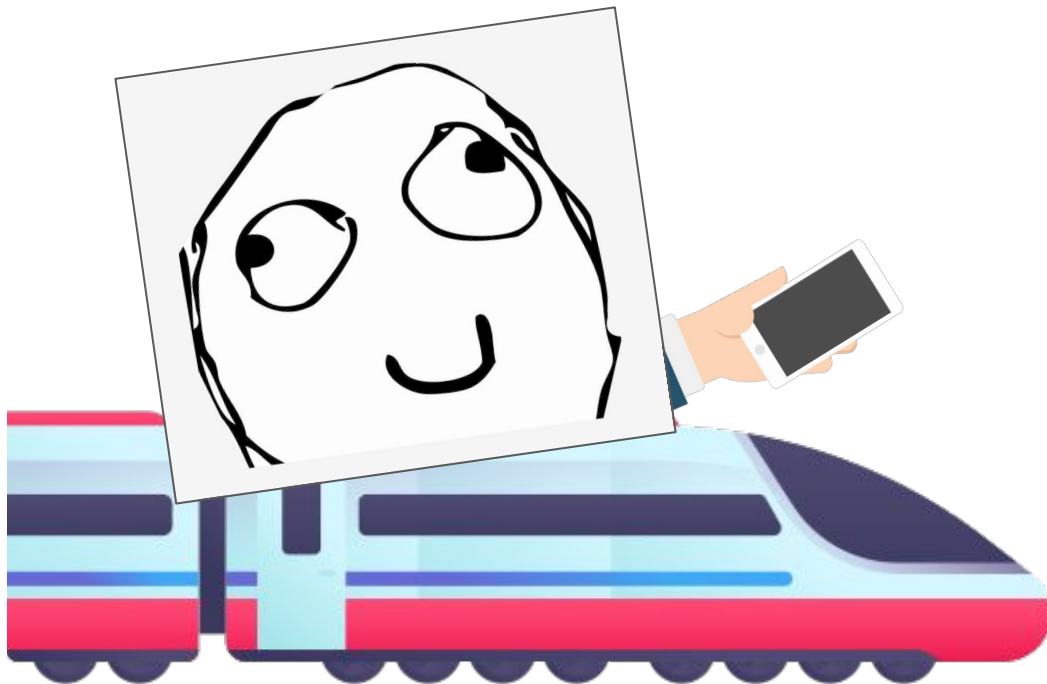
Enter  
Ticket



Entrance

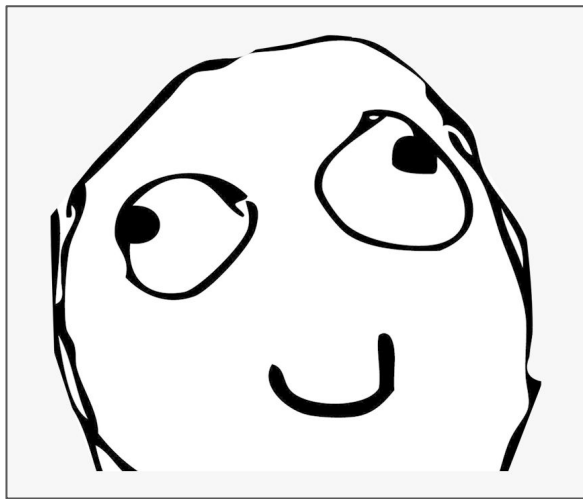


# Having Fun Ride





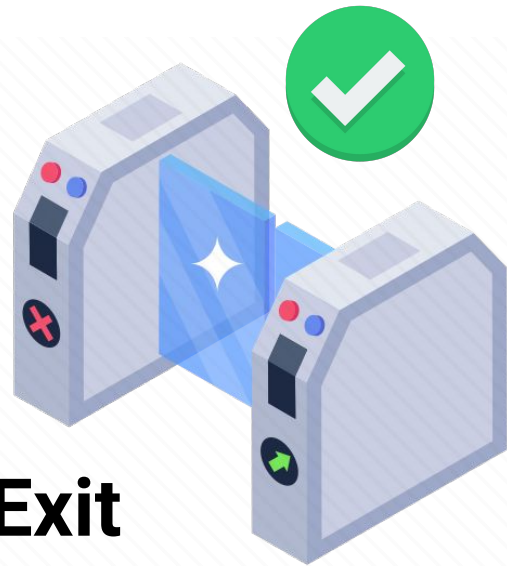
# Cancel & Use



Enter  
Ticket

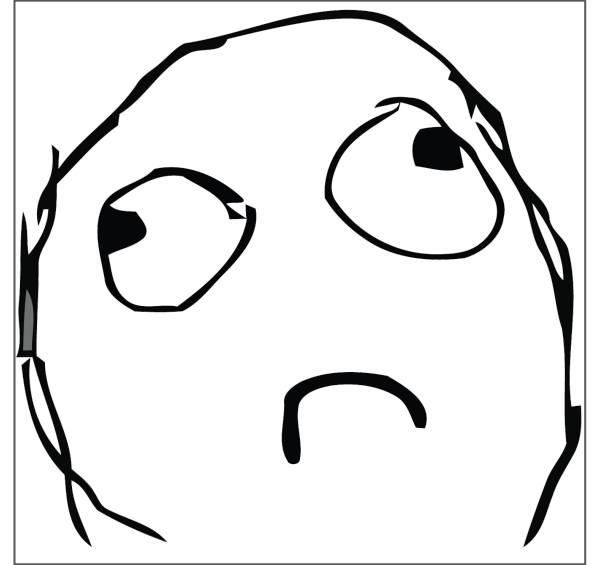


Exit

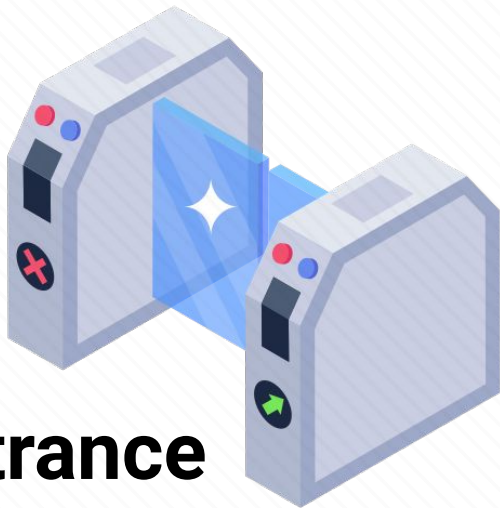


# Cancel & Use

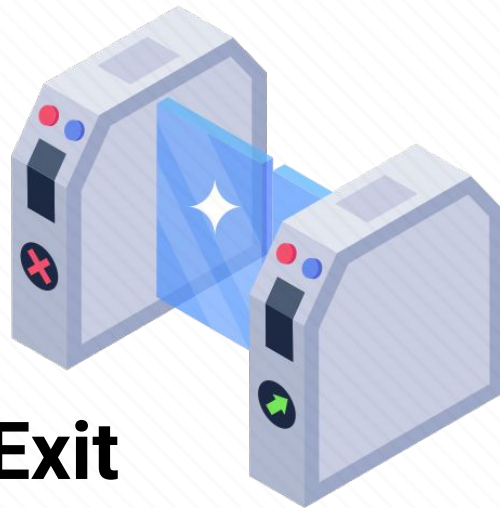
The fare from your 08/05/2023 08:30 ride has been updated, according to the information from the Ministry of Transport. Check My Rides for the updated fare.



# What Probably Happened?

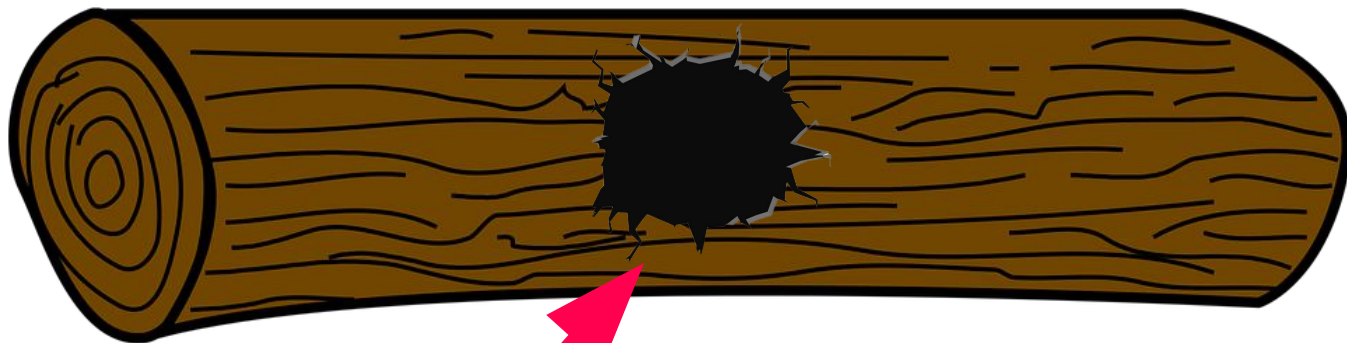


**Entrance**



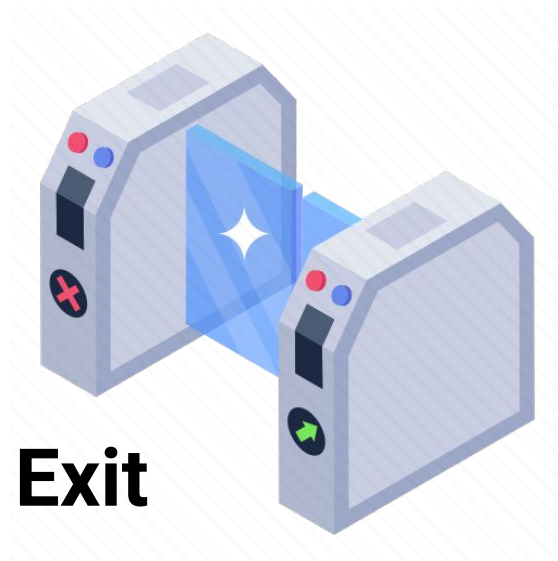
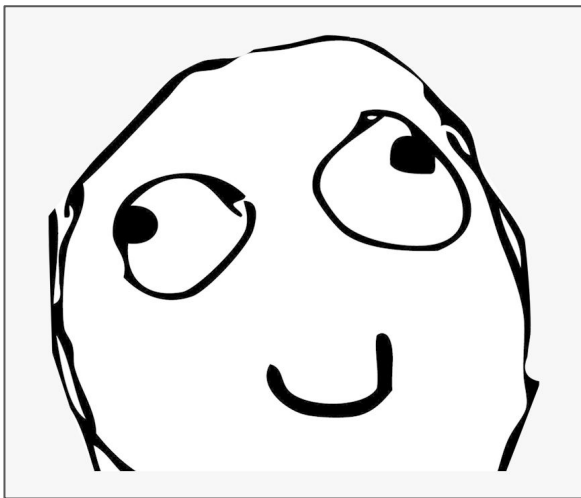
**Exit**

# Hole In The Log

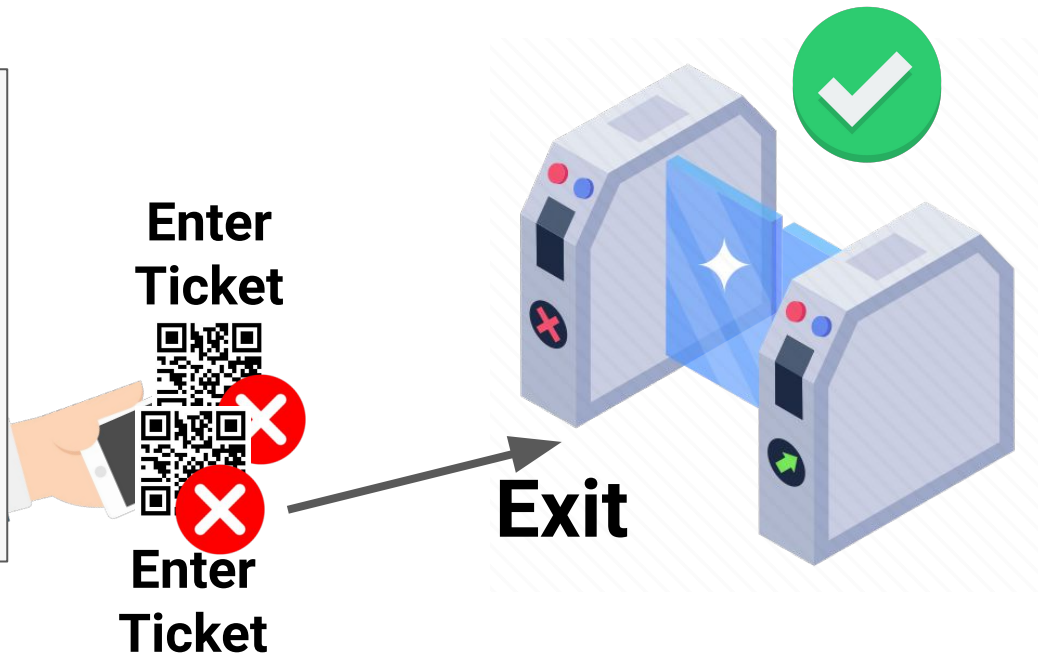
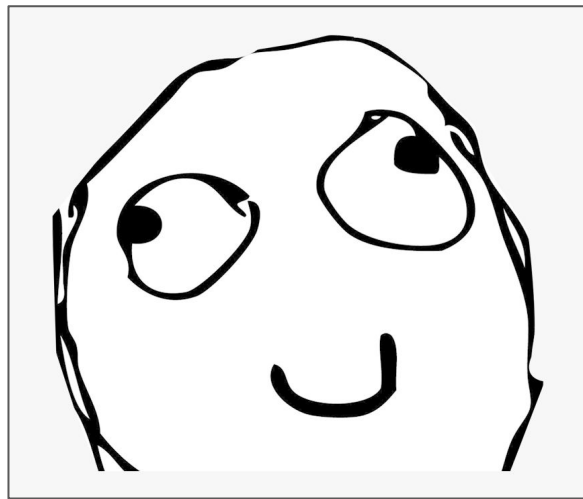


**Hole**

# Hole In The Log



# Hole In The Log



# Summarize

- How mobile solution works

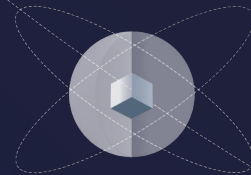


- How to trick the gates



# Moovit

(MaaS Operator)



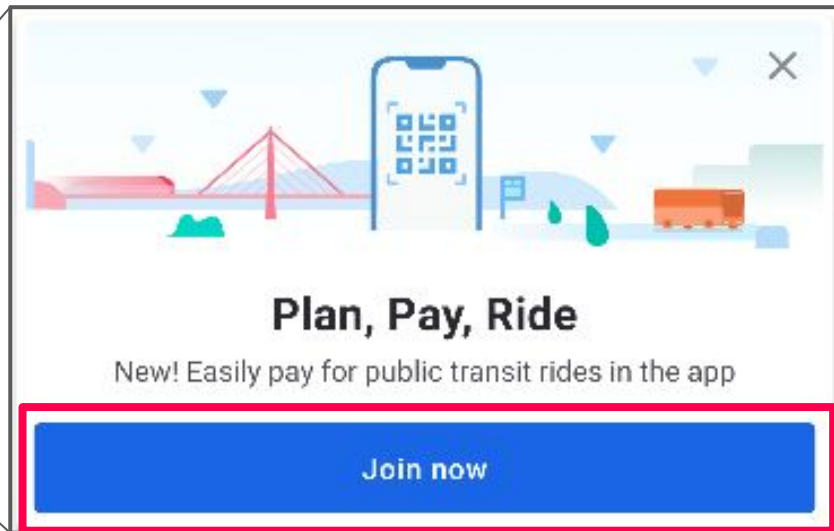
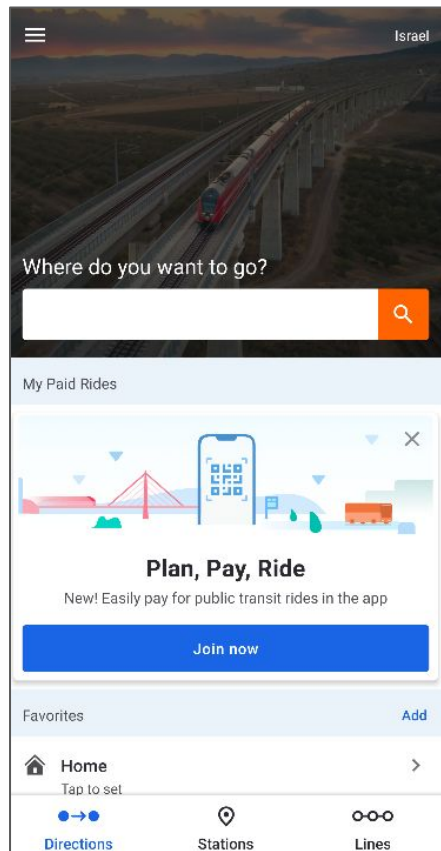


# Moovit Overview

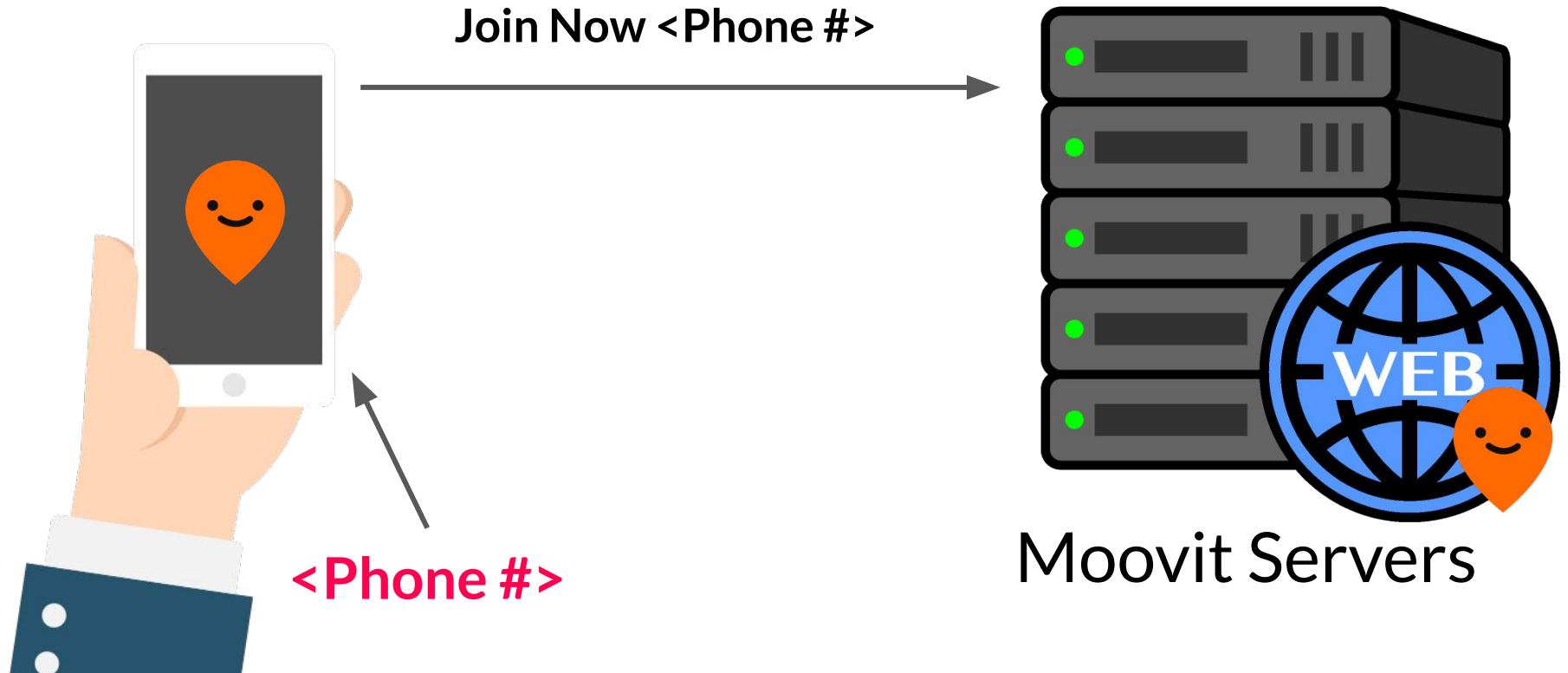
- Leading MaaS Operator
- Acquired by Intel at 900m \$
- 1.4 Billion users
- 100 Countries
- 5000+ Cities



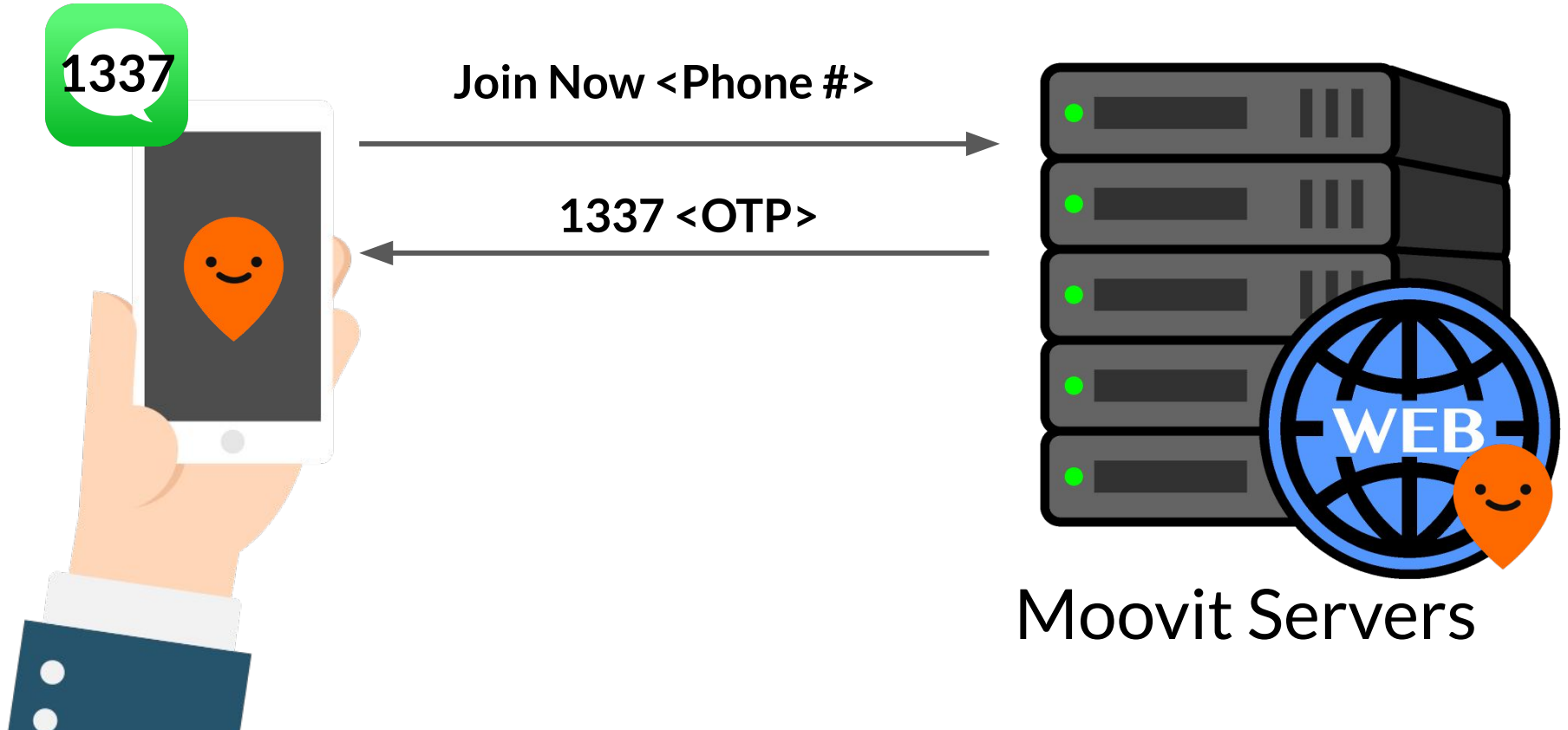
# Moovit Interface



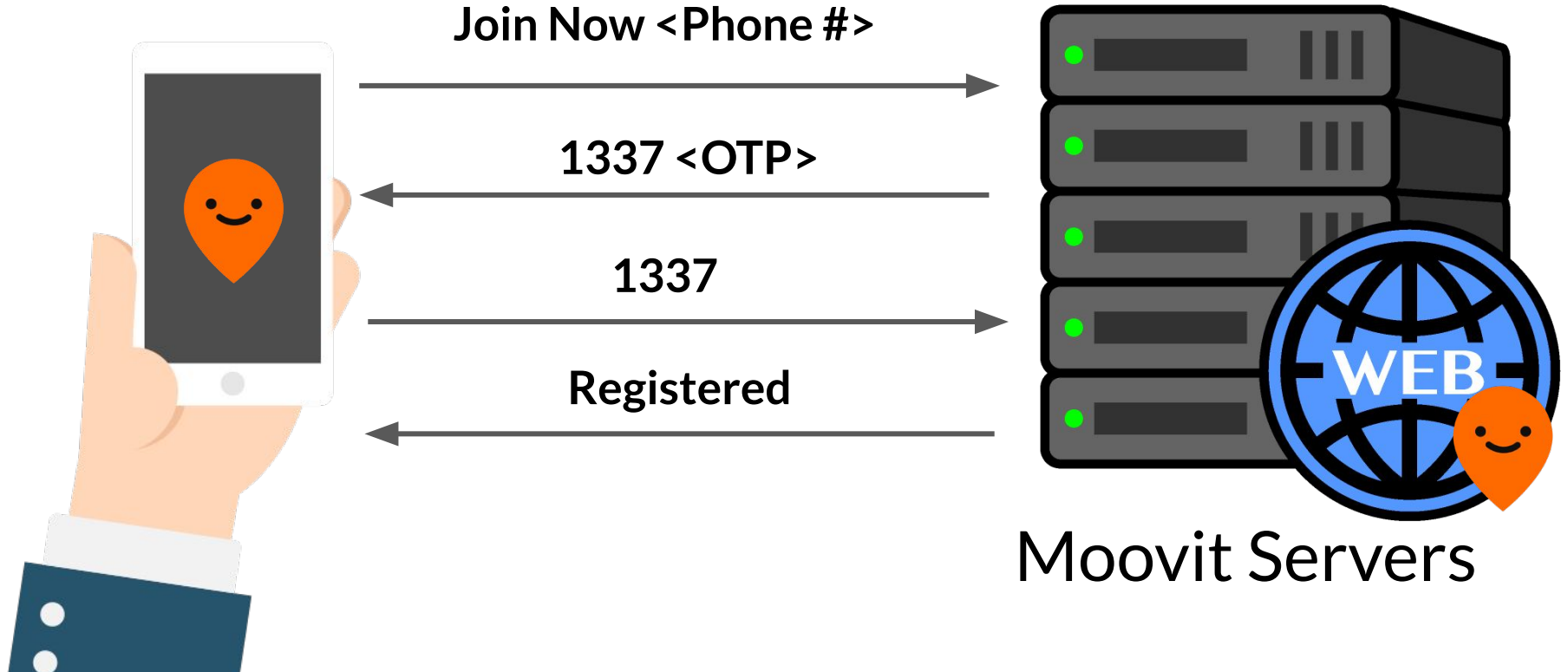
# Account Registration



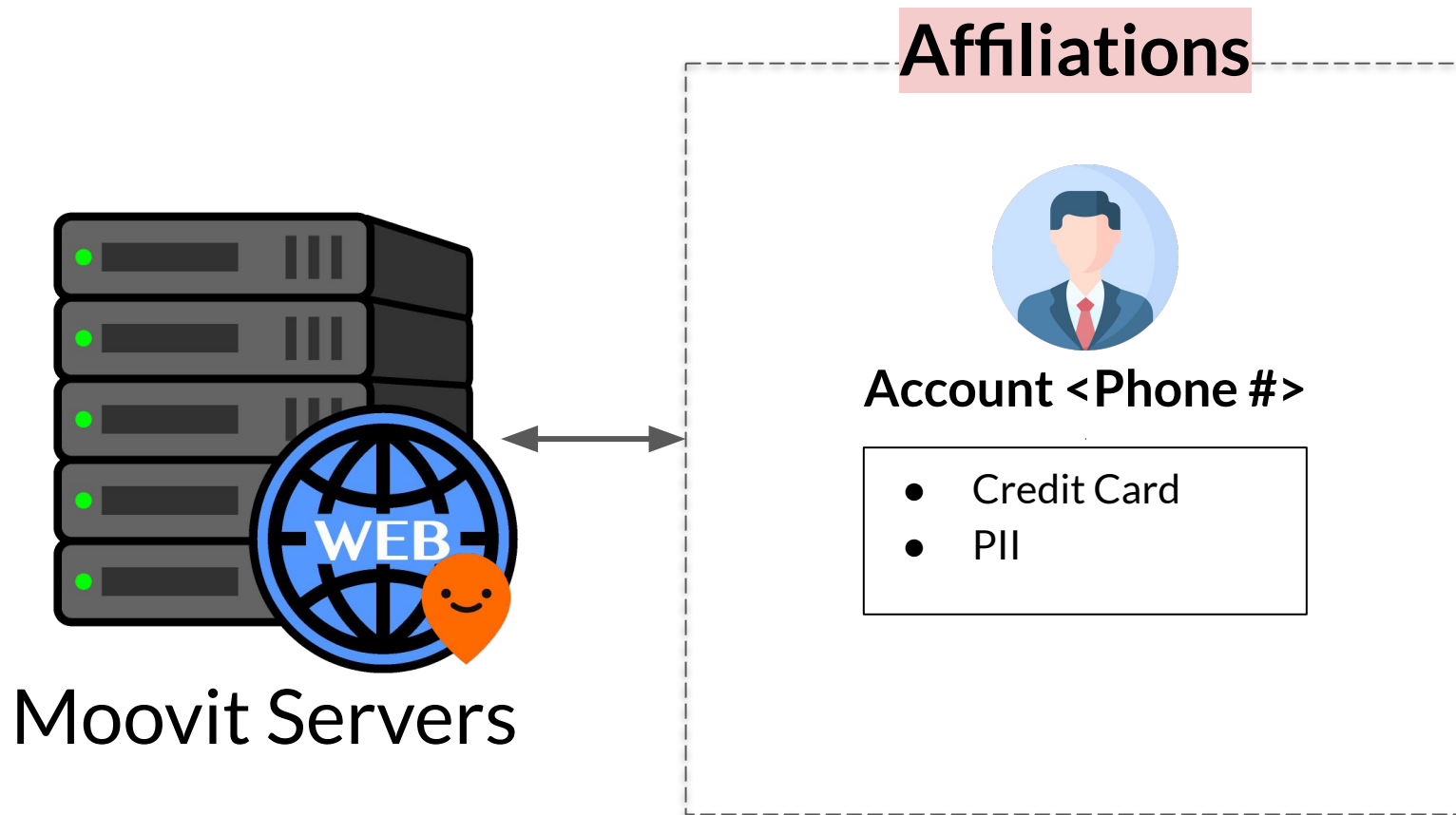
# Account Registration



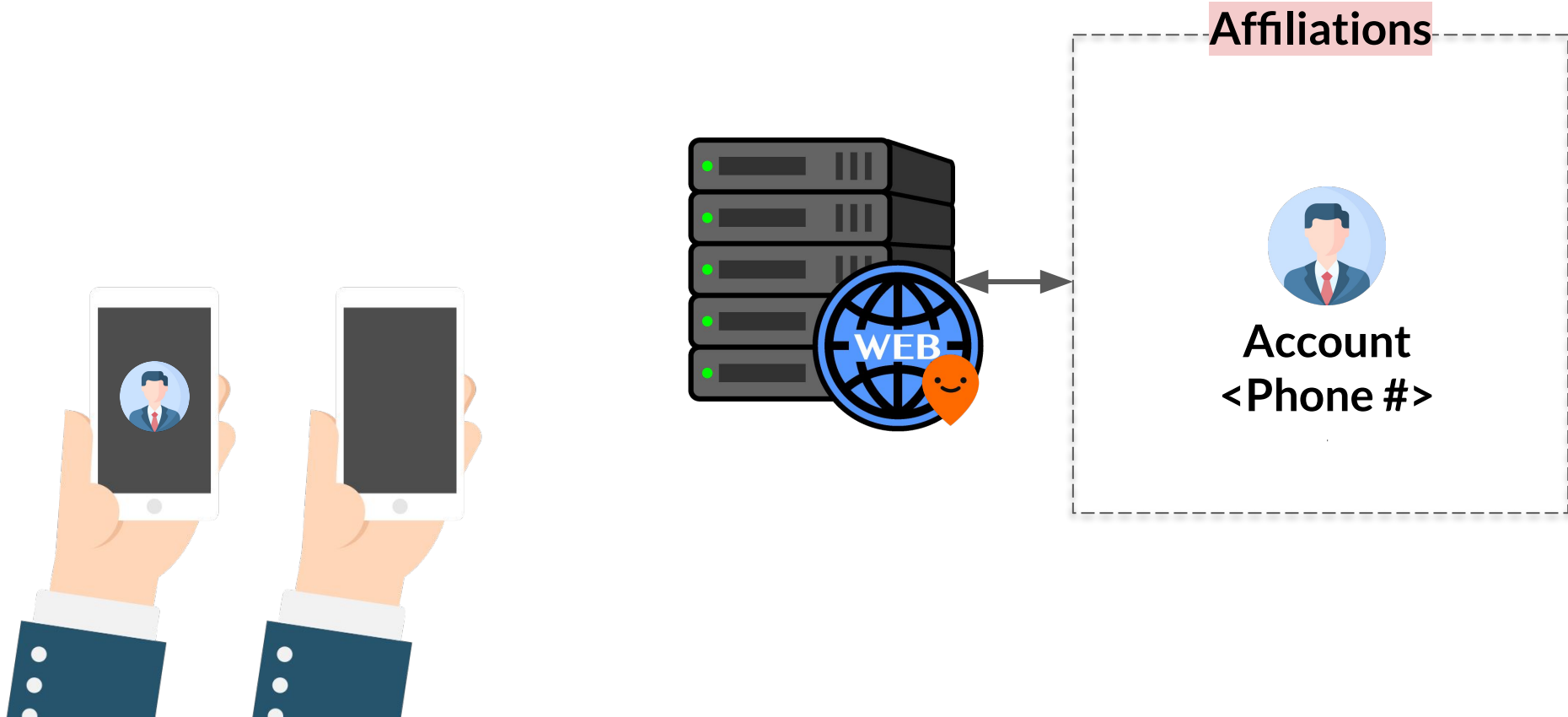
# Account Registration



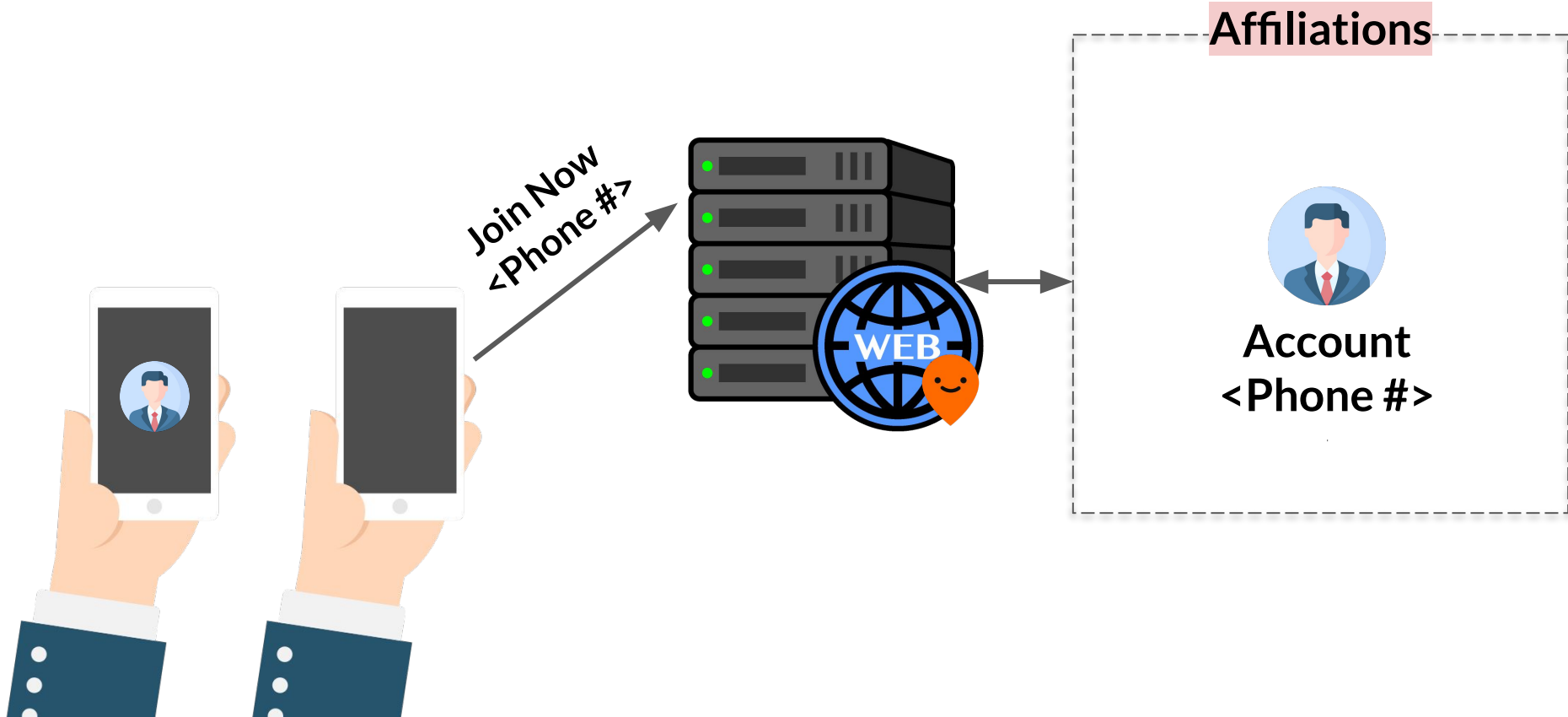
# Account Affiliation



# Existing Account But Another Device

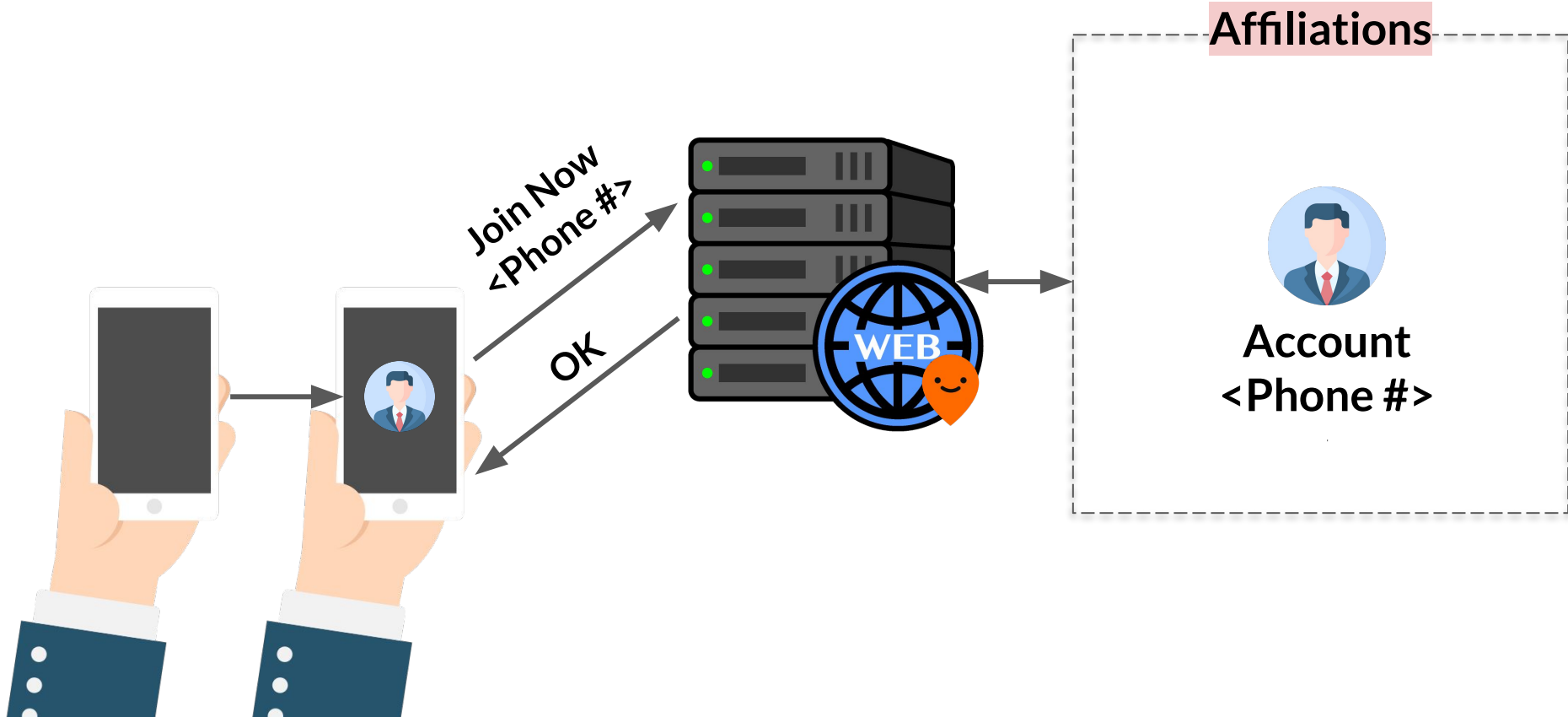


# Existing Account But Another Device



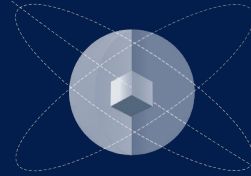


# Existing Account But Another Device



# Vulnerability #1

ABC Of API Security



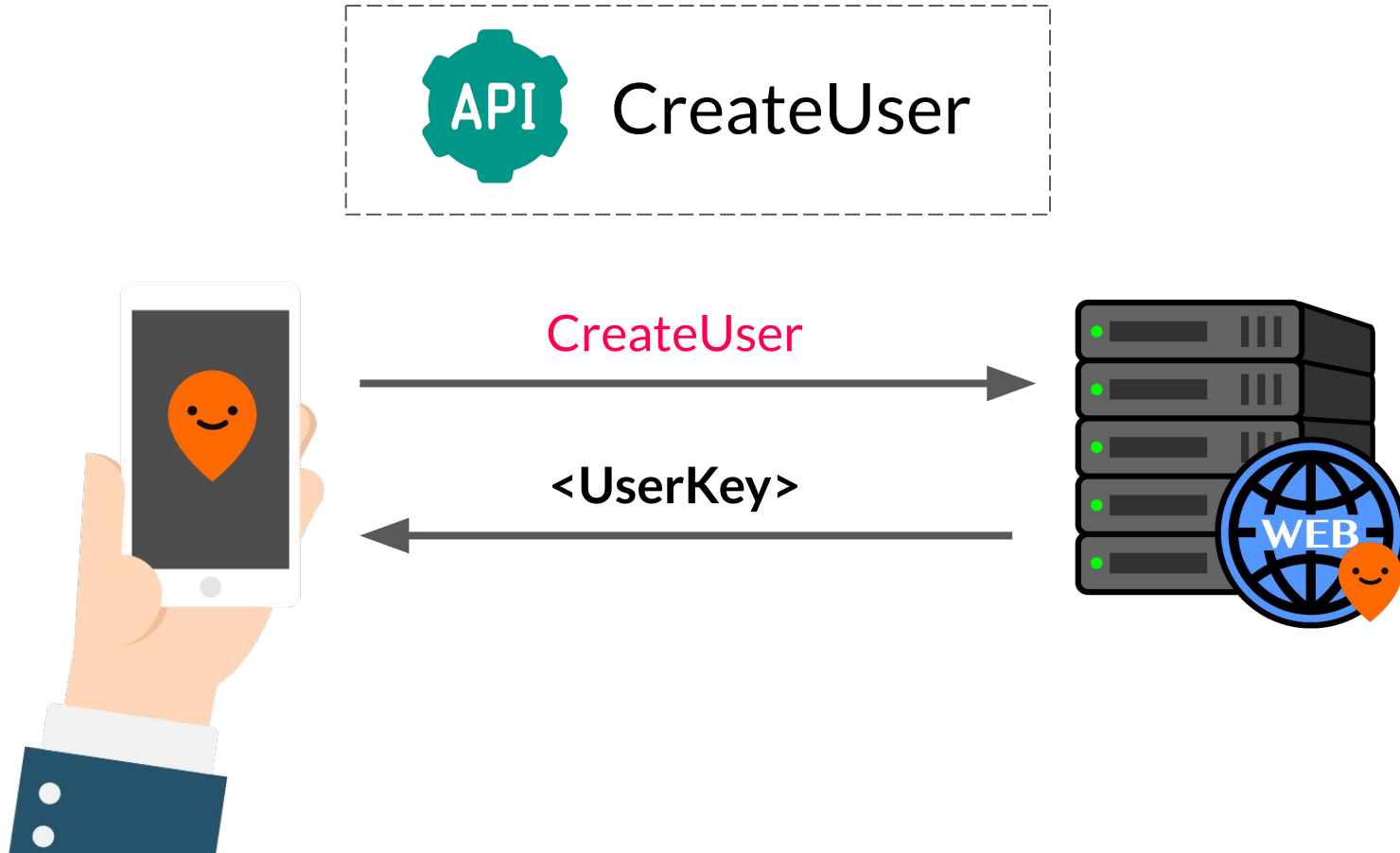
# SSL Unpinning

```
$ frida -U -l .\ssl_unpinning.js -f com.tranzmate
```

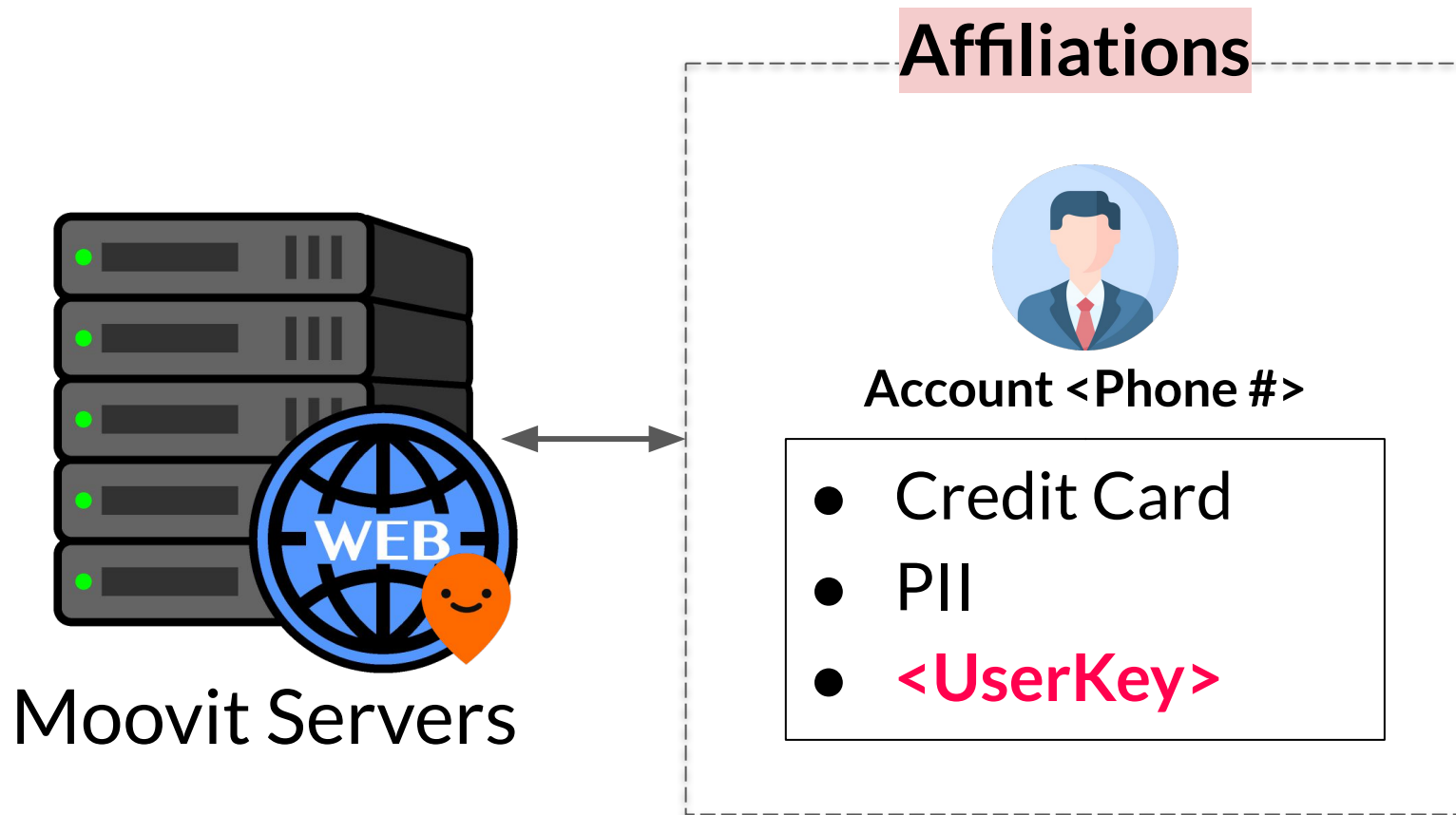
```

  _ _ _ _
 / _ |   Frida 16.0.8 - A world-class dynamic instrumentation toolkit
| ( _ |
 > _ |
/_/_/_|_ |
. . . .
. . . .
. . . .
. . . .
. . . .
. . . .
More info at https://frida.re/docs/home/
```

# The First API Request



# Account To UserKey



# Assume That ...



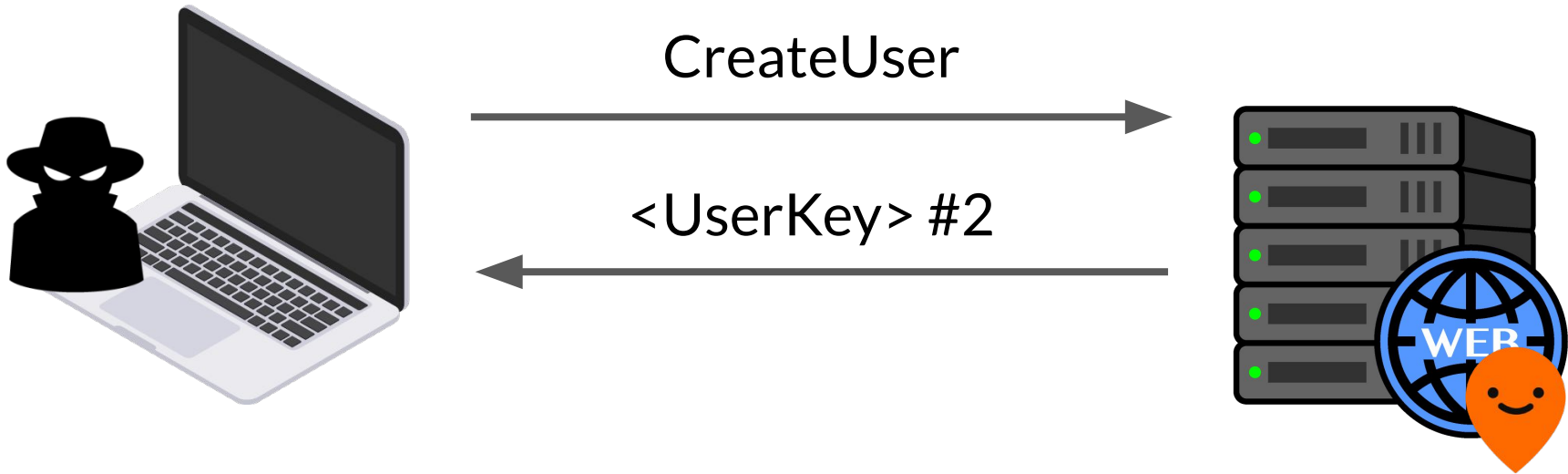
## Affiliations



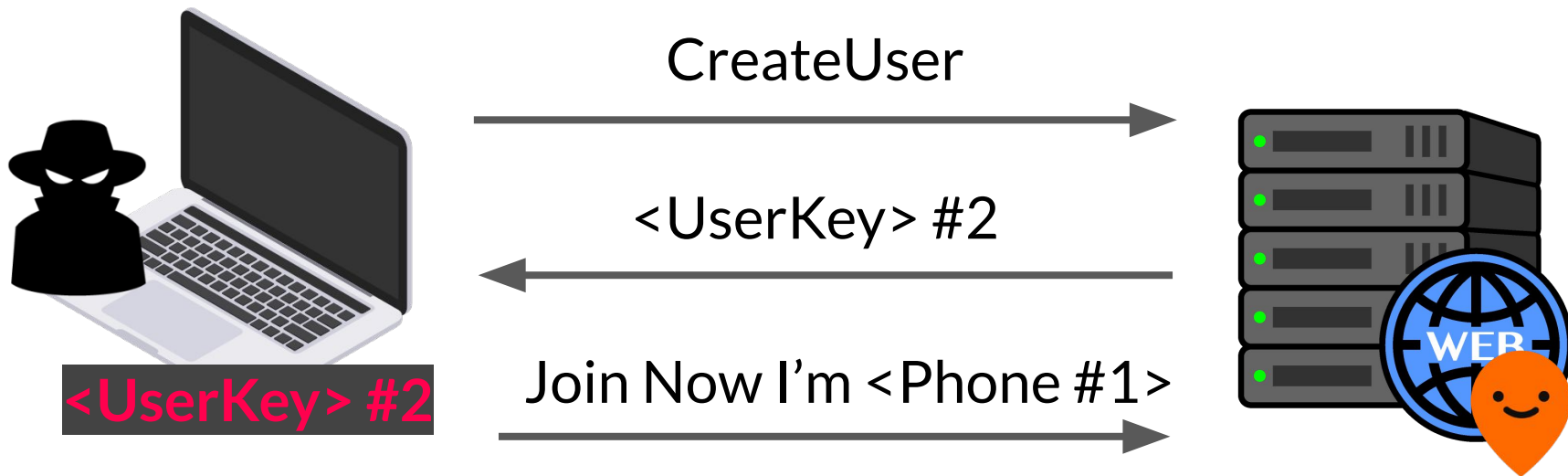
Account <Phone #1>

- Credit Card
- PII
- <UserKey> #1

# Pretending to Be Other Device

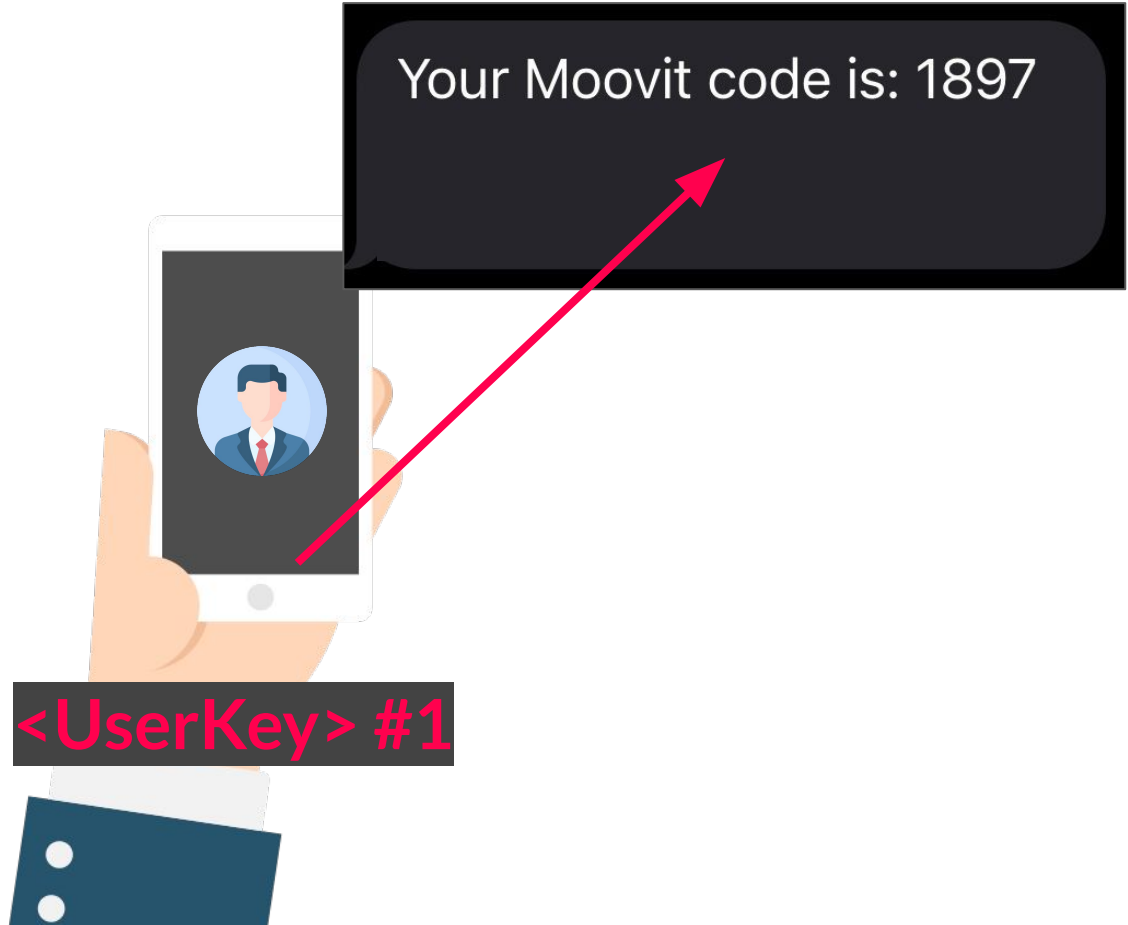


# Pretending to Be Other Device

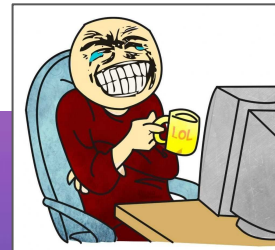




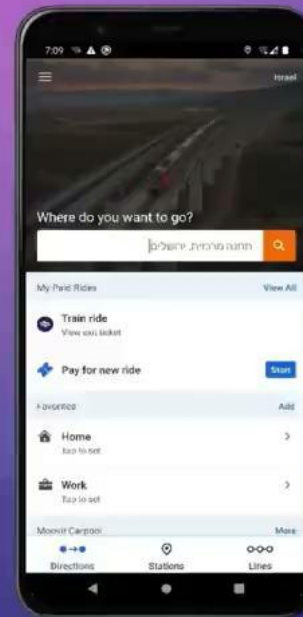
# The Unexpected Vulnerability



# Hijacking Account



```
omeratt@DESKTOP-0E3L1A0 in ~\work\research\moovit\scripts [14:08:37]  
$
```

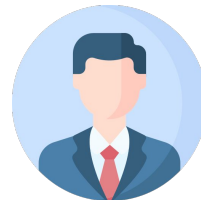


# Affiliation Change



**<UserKey> #2**

## Affiliations



Account <Phone #>

- Credit Card
- PII
- **<UserKey> #2**

# Pros & Cons



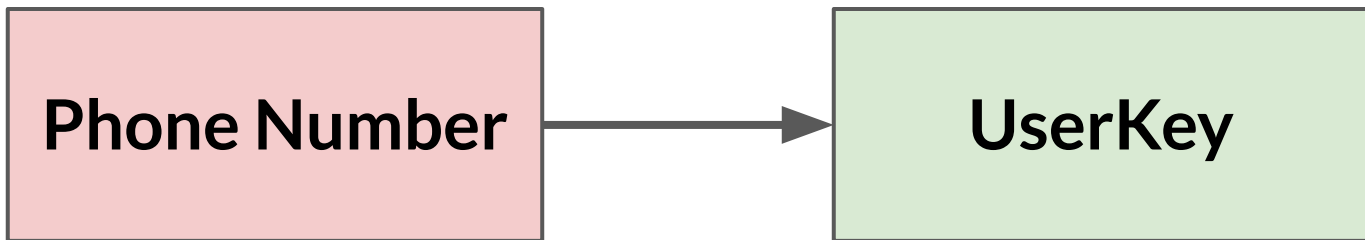
- Targeted Attack



- Takes time
- Disconnect the account
- Requires account phone number

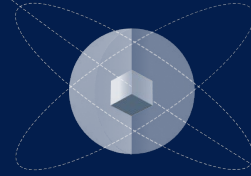
# Complexity Reduction

Transforming **one problem** into **another problem**



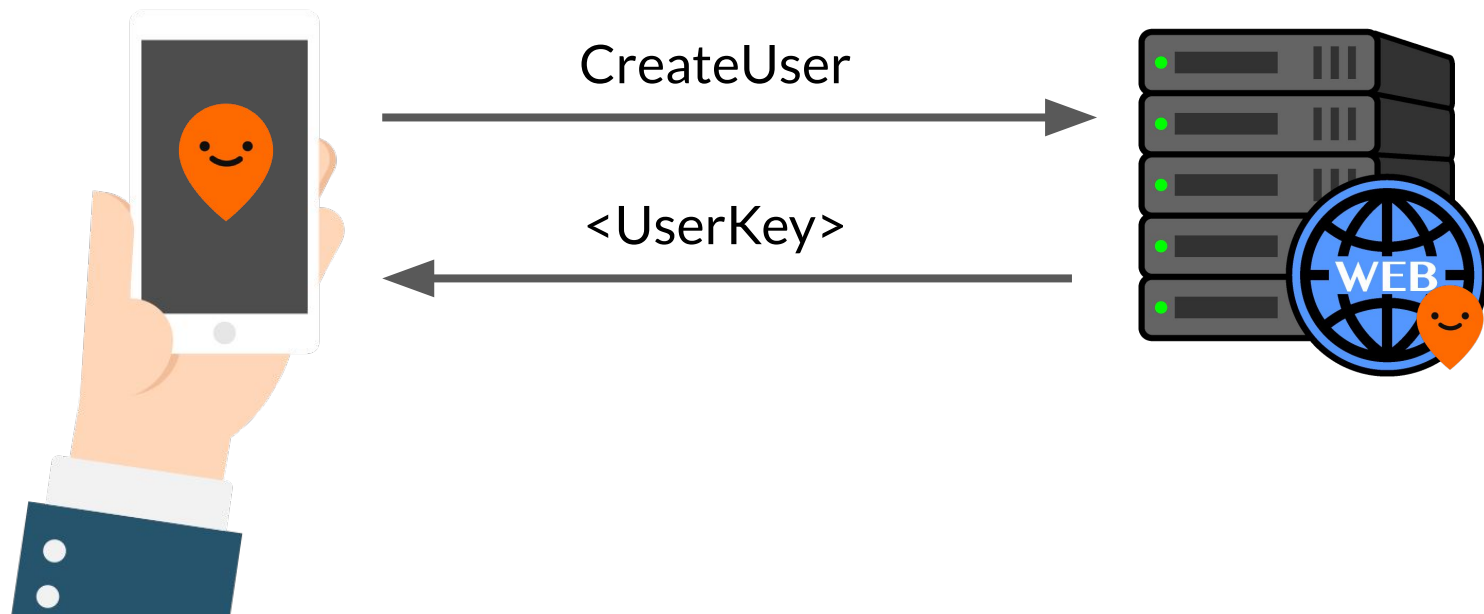
# UserKey Breakdown

Vulnerability #2

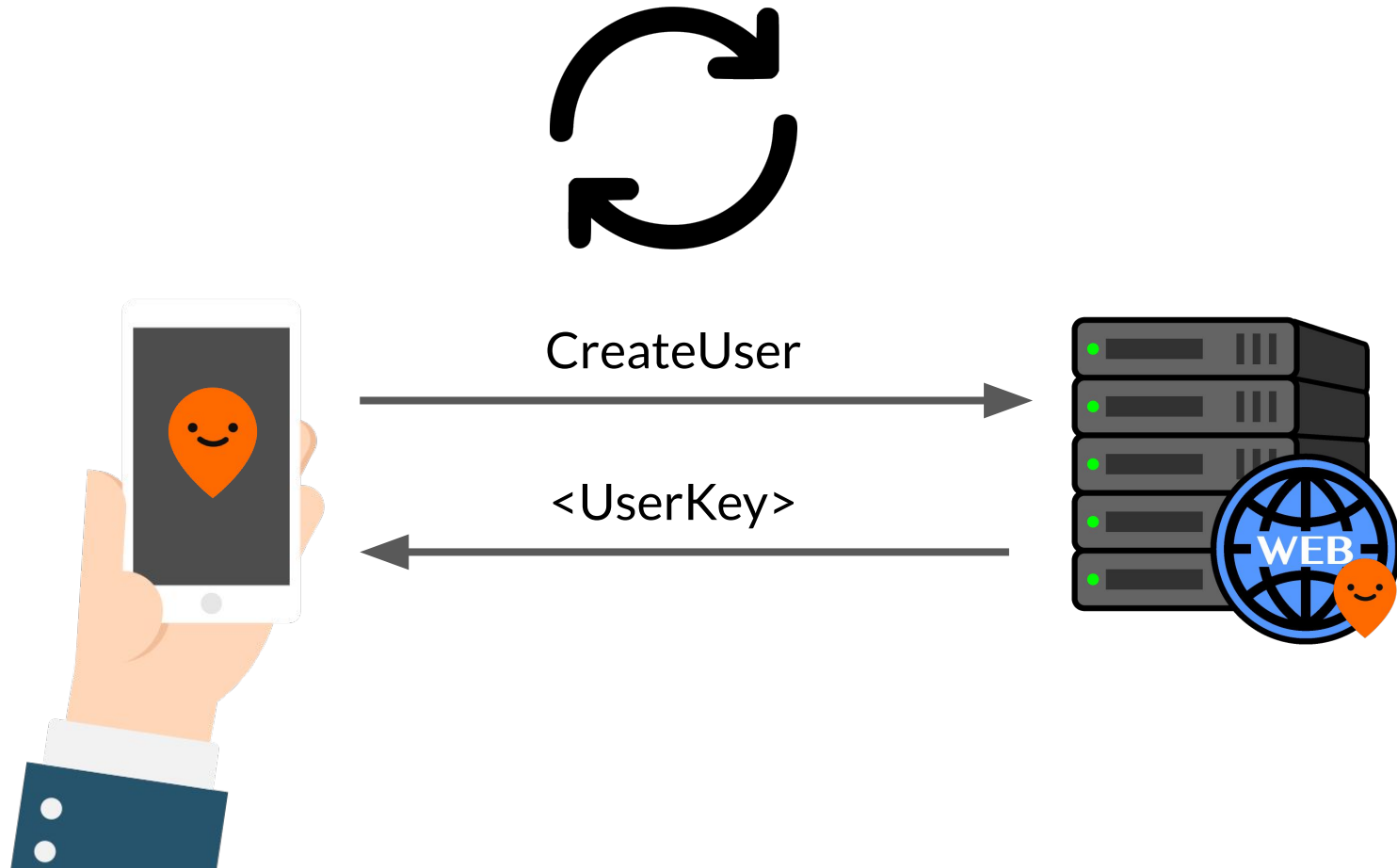


# UserKey Format

E4C6F3B1EFF23008E0530100007FE981



# Collecting Samples





## Breaking Down The Format

|       |                                  |
|-------|----------------------------------|
| 24839 | E4C6EF59767626E3E0530100007F6289 |
| 24840 | E4C843B62A151E26E0530100007F818F |
| 24841 | E4C81C630E6042DDE0530100007FA1DC |
| 24842 | E4C9AD60C8503275E0530100007F11CE |
| 24843 | E4C8AB401AD20F6CE0530100007F1EAA |
| 24844 | E4C96EEC3A3F7D98E0530100007FE41A |
| 24845 | E4C7B0DA1F284975E0530100007FAFAA |
| 24846 | E4C81C630E9942DDE0530100007FA1DC |

## Breaking Down The Format

|       |                                  |
|-------|----------------------------------|
| 24839 | E4C6EF59767626E3E0530100007F6289 |
| 24840 | E4C843B62A151E26E0530100007F818F |
| 24841 | E4C81C630E6042DDE0530100007FA1DC |
| 24842 | E4C9AD60C8503275E0530100007F11CE |
| 24843 | E4C8AB401AD20F6CE0530100007F1EAA |
| 24844 | E4C96EEC3A3F7D98E0530100007FE41A |
| 24845 | E4C7B0DA1F284975E0530100007FAFAA |
| 24846 | E4C81C630E9942DDE0530100007FA1DC |

# Oracle SYS\_GUID

## Purpose

SYS\_GUID generates and returns a globally unique identifier (RAW value) made up of 16 bytes. On most platforms, the generated identifier consists of a host identifier, a process or thread identifier of the process or thread invoking the function, and a nonrepeating value (sequence of bytes) for that process or thread.

UID\_COL

```
-----  
7CD5B7769DF75CEFE034080020825436  
7CD5B7769DF85CEFE034080020825436  
7CD5B7769DF95CEFE034080020825436  
7CD5B7769DFA5CEFE034080020825436
```

# Oracle SYS\_GUID

## Purpose

SYS\_GUID generates and returns a globally unique identifier (RAW value) made up of 16 bytes. On most platforms, the generated identifier consists of a host identifier, a process or thread identifier of the process or thread invoking the function, and a nonrepeating value (sequence of bytes) for that process or thread.

UID\_COL

```
-----  
7CD5B7769DF75CEFE034080020825436  
7CD5B7769DF85CEFE034080020825436  
7CD5B7769DF95CEFE034080020825436  
7CD5B7769DFA5CEFE034080020825436
```



## Breaking Down The Format

|       |                  |              |      |
|-------|------------------|--------------|------|
| 24839 | E4C6EF59767626E3 | E0530100007F | 6289 |
| 24840 | E4C843B62A151E26 | E0530100007F | 818F |
| 24841 | E4C81C630E6042DD | E0530100007F | A1DC |
| 24842 | E4C9AD60C8503275 | E0530100007F | 11CE |
| 24843 | E4C8AB401AD20F6C | E0530100007F | 1EAA |
| 24844 | E4C96EEC3A3F7D98 | E0530100007F | E41A |
| 24845 | E4C7B0DA1F284975 | E0530100007F | AFAA |
| 24846 | E4C81C630E9942DD | E0530100007F | A1DC |

# Breaking Down The Format

|       |                                   |
|-------|-----------------------------------|
| 24839 | E4C6EF59767626E3E0530100007F6289  |
| 24840 | E4C843B62A151E26E0530100007F818F  |
| 24841 | E4C81C630E6042DD E0530100007FA1DC |
| 24842 | E4C9AD60C8503275E0530100007F11CE  |
| 24843 | E4C8AB401AD20F6CE0530100007F1EAA  |
| 24844 | E4C96EEC3A3F7D98E0530100007FE41A  |
| 24845 | E4C7B0DA1F284975E0530100007FAFAA  |
| 24846 | E4C81C630E9942DD E0530100007FA1DC |

The diagram illustrates a repeating pattern in the data. Two specific hex values, 42DD and FA1DC, are highlighted with red boxes in rows 24841 and 24846. Vertical double-headed arrows connect these boxes between the two rows, indicating that the same sequence of values repeats. The pattern shows 42DD followed by FA1DC, which then repeats in the next row.

## Breaking Down The Format

|      |                                  |
|------|----------------------------------|
| 9727 | E4C81C630E1C42DDE0530100007FA1DC |
| 9728 | E4C81C630E1D42DDE0530100007FA1DC |
| 9729 | E4C81C630E1E42DDE0530100007FA1DC |
| 9730 | E4C81C630E1F42DDE0530100007FA1DC |
| 9731 | E4C81C630E2042DDE0530100007FA1DC |
| 9732 | E4C81C630E2142DDE0530100007FA1DC |
| 9733 | E4C81C630E2242DDE0530100007FA1DC |
| 9734 | E4C81C630E2342DDE0530100007FA1DC |



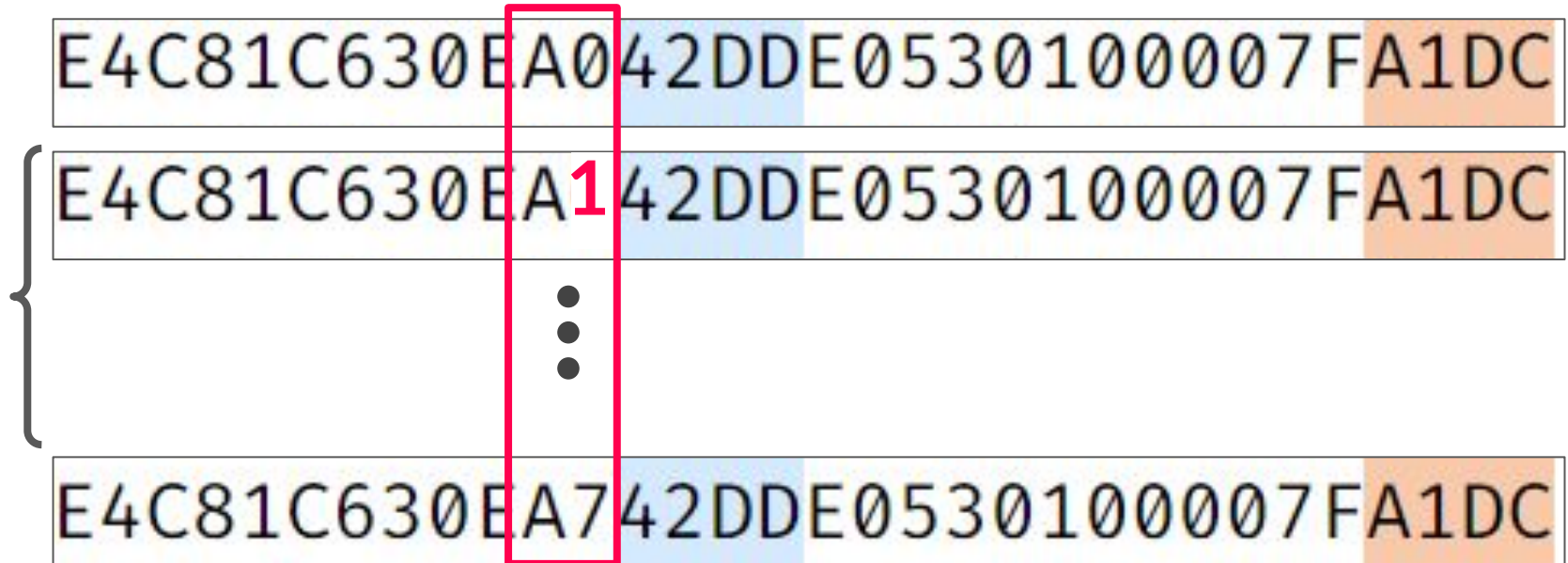
## Why Do We Have Gaps?

|            |    |                  |      |
|------------|----|------------------|------|
| E4C81C630E | A0 | 42DDE0530100007F | A1DC |
| E4C81C630E | A7 | 42DDE0530100007F | A1DC |

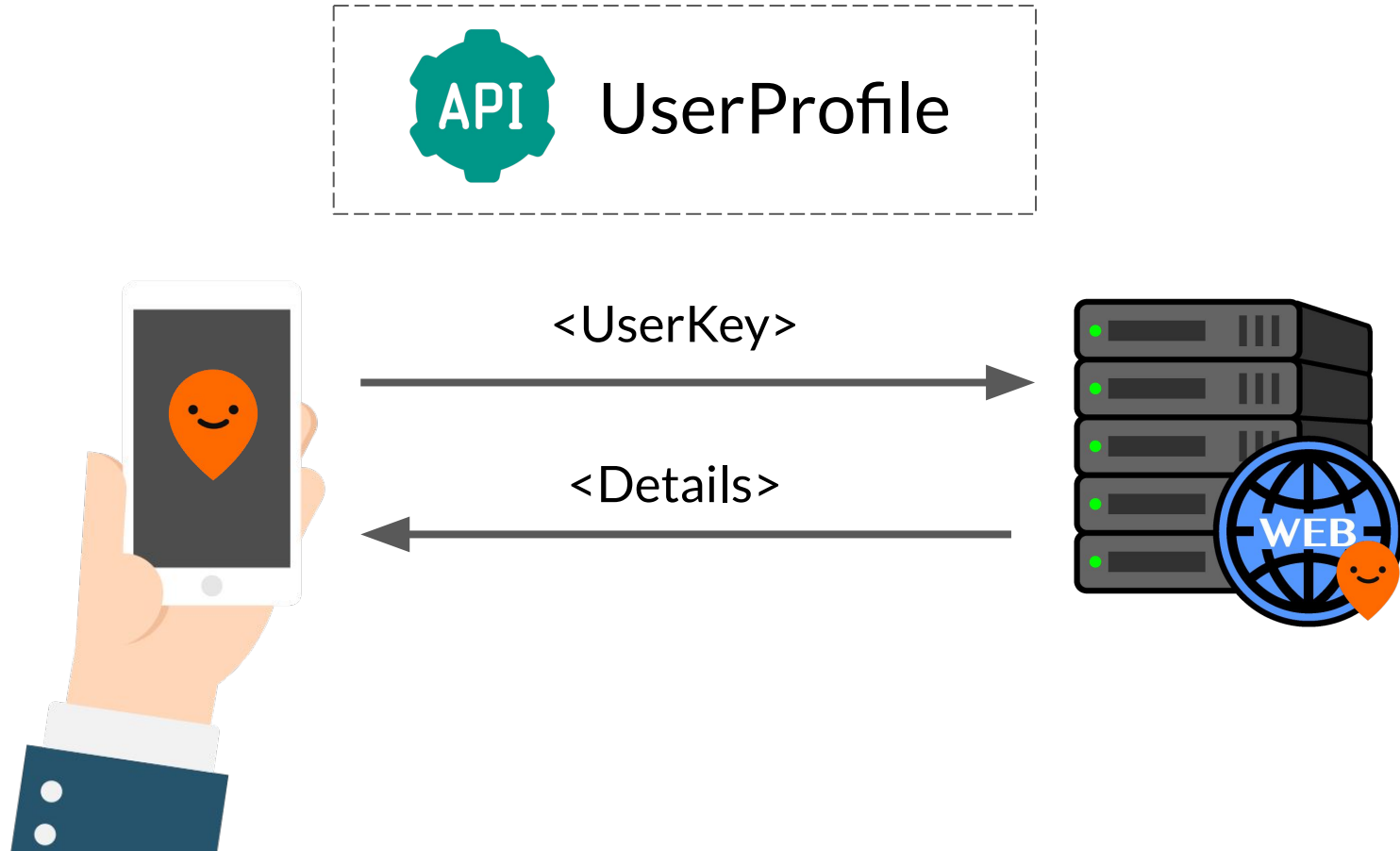
$$(A0, A7) = \{A1, A2, A3, A4, A5, A6\}$$



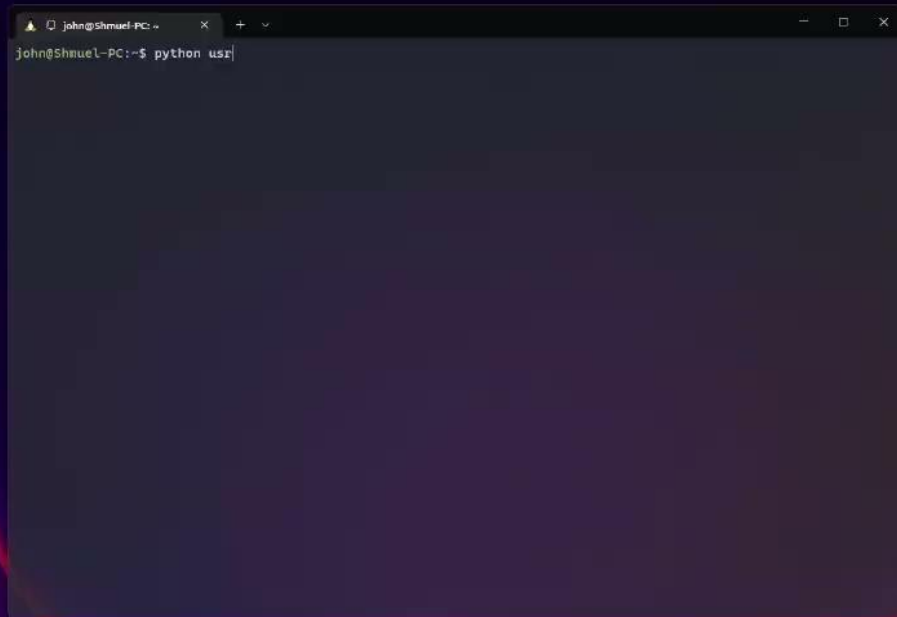
## Filling The Gaps



# UserProfile API Request



# Getting Phone Numbers

A terminal window with a dark background and a title bar that reads 'john@shmael-PC: ~'. The window contains the command 'python usr' followed by a cursor. The background of the slide features a large, glowing, semi-circular arc in shades of purple and pink.

```
john@shmael-PC: ~  
john@shmael-PC:~$ python usr
```

# A Few Moments Later



# Accounts Around The World

|    |                    |     |                                  |    |     |
|----|--------------------|-----|----------------------------------|----|-----|
| 1  | [+][Found Profile] | --> | E78E43310A806DD9E0530100007F6E7B | -> | +15 |
| 2  | [+][Found Profile] | --> | E78F48144E6907F6E0530100007F9C84 | -> | +48 |
| 3  | [+][Found Profile] | --> | E78F56E76ED816FEE0530100007FF967 | -> | +13 |
| 4  | [+][Found Profile] | --> | E78F685DBB0B2801E0530100007F499E | -> | +31 |
| 5  | [+][Found Profile] | --> | E78F6C75EA3F2B4AE0530100007FF770 | -> | +17 |
| 6  | [+][Found Profile] | --> | E78F6AFBF0A629FFE0530100007F76D3 | -> | +17 |
| 7  | [+][Found Profile] | --> | E78F785DBBE137F6E0530100007FFAA4 | -> | +16 |
| 8  | [+][Found Profile] | --> | E78F7737FD0D362DE0530100007FA69B | -> | +13 |
| 9  | [+][Found Profile] | --> | E78FF776D7B93E93E0530100007F9BBF | -> | +33 |
| 10 | [+][Found Profile] | --> | E7900E50E4B456ECE0530100007FAD43 | -> | +15 |
| 11 | [+][Found Profile] | --> | E7900035516346D0E0530100007F7250 | -> | +15 |
| 12 | [+][Found Profile] | --> | E79029DF624C7503E0530100007FC2D8 | -> | +12 |
| 13 | [+][Found Profile] | --> | E7903443DB317EABE0530100007F58C3 | -> | +15 |
| 14 | [+][Found Profile] | --> | E7903443DB3E7EABE0530100007F58C3 | -> | +15 |
| 15 | [+][Found Profile] | --> | E7902662D81A6F08E0530100007F02A1 | -> | +12 |
| 16 | [+][Found Profile] | --> | E79044E65D490E6CE0530100007F7B91 | -> | +16 |
| 17 | [+][Found Profile] | --> | E7901BFE1C5F6151E0530100007FD8C3 | -> | +17 |
| 18 | [+][Found Profile] | --> | E79044E65D710E6CE0530100007F7B91 | -> | +16 |
| 19 | [+][Found Profile] | --> | E7904119814B0D31E0530100007FEBF0 | -> | +31 |
| 20 | [+][Found Profile] | --> | E7904A5A6AD5151AE0530100007FA616 | -> | +16 |
| 21 | [+][Found Profile] | --> | E7903F298C510B5EE0530100007F70B0 | -> | +44 |
| 22 | [+][Found Profile] | --> | E7906E574A403DBAE0530100007F39BE | -> | +13 |
| 23 | [+][Found Profile] | --> | E7906E574A413DBAE0530100007F39BE | -> | +12 |
| 24 | [+][Found Profile] | --> | E79073533AA943EEE0530100007FFEFD | -> | +19 |
| 25 | [+][Found Profile] | --> | E79074EF650945AAE0530100007FA733 | -> | +31 |
| 26 | [+][Found Profile] | --> | E79073533ADB43EEE0530100007FFEFD | -> | +32 |

# Pros & Cons



- Targeted Attack



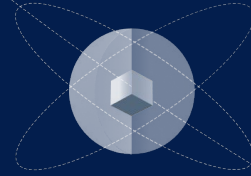
- Takes time
- Disconnect the account
- ~~Requires account phone number~~

# How Can We Improve This?



# Enhancing Capabilities

Vulnerability #3

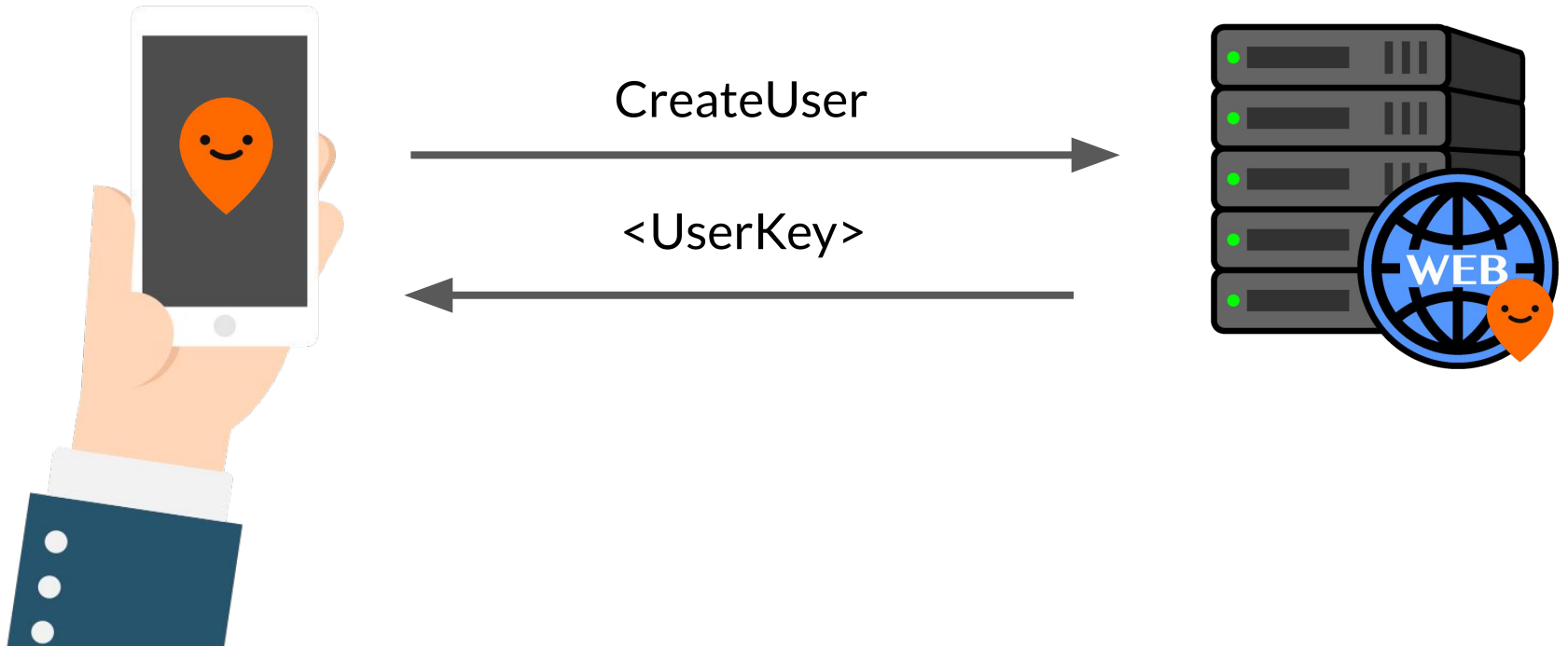




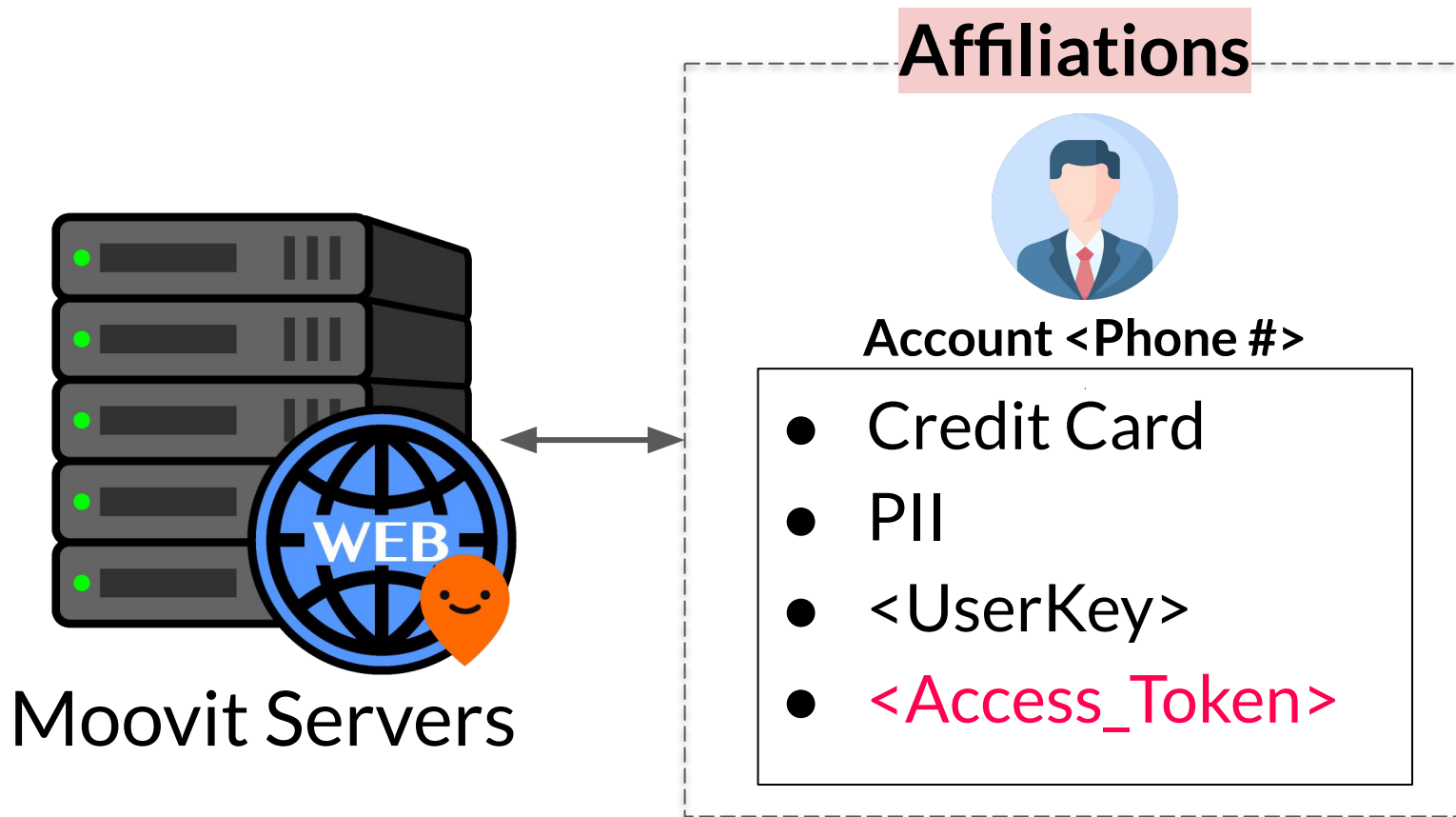
# Delve Into The APIs



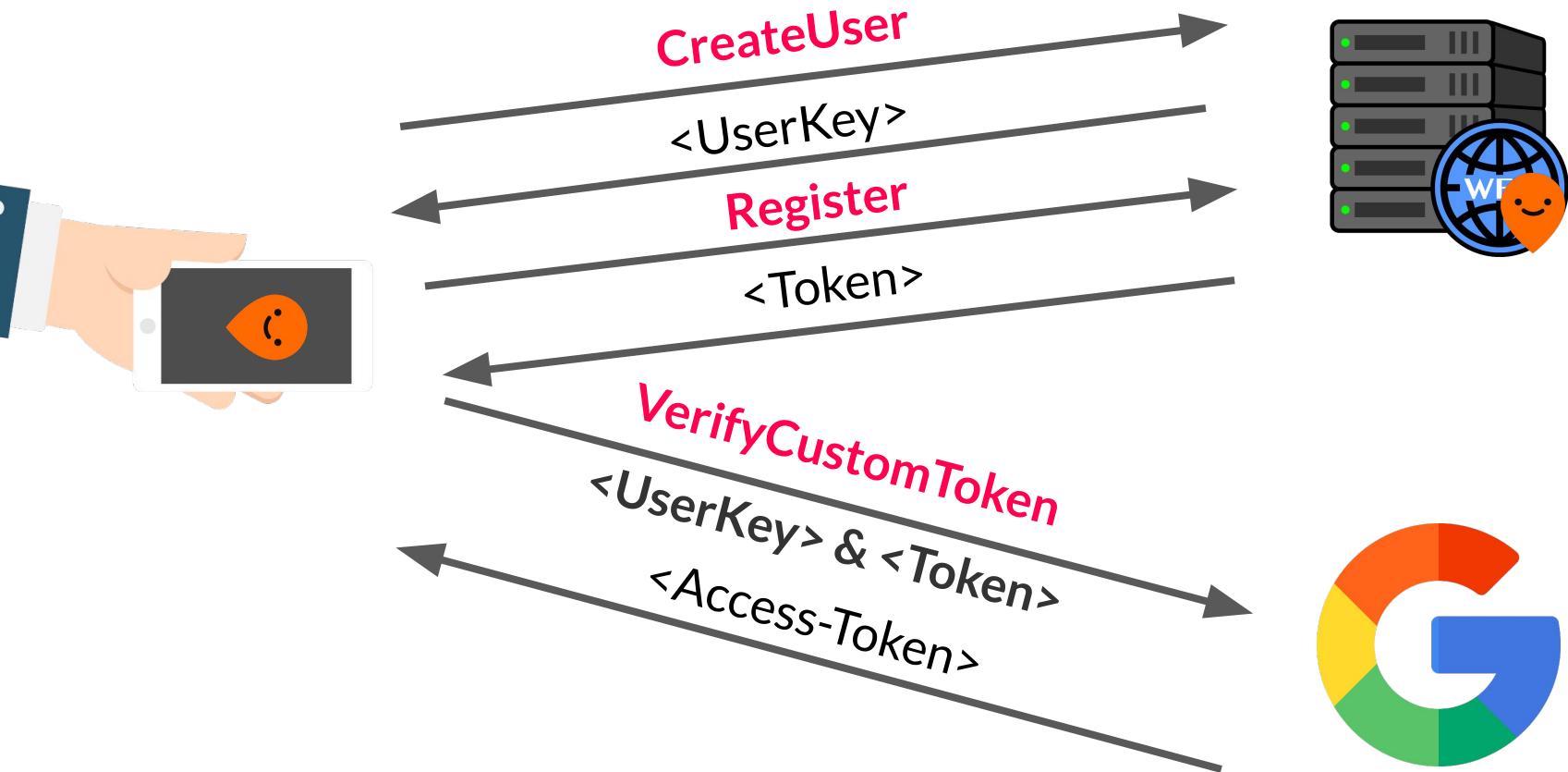
# Reminder - The First API Request



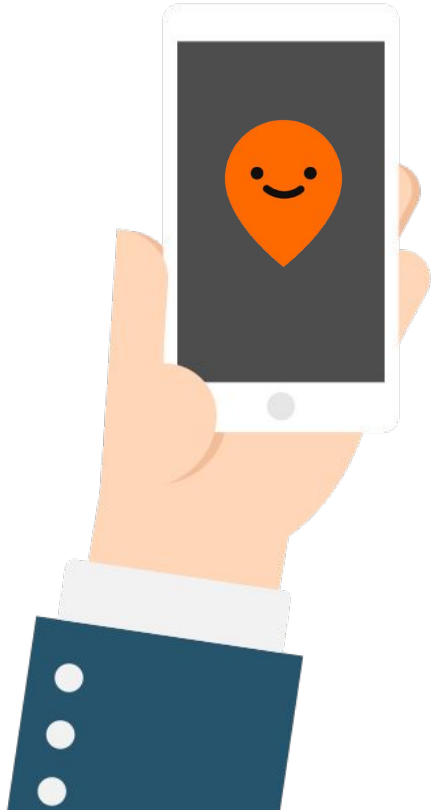
# Access Token



# Device Setup



# Now, Everything Is Set



<AccessToken>



<UserKey>

# The Problem



<UserKey>

# JWT Access Token

```
eyJhbGciOiJSUzI1NiIsImtpZCI6IjU4NWl5MGI1OWM2YjM2ZDNjOTBkZjB1OTEwNDQ1M2U2MmY4ODdmNzciLCJ0eXAiOiJKV1QiLCJ0eXN0eXBvczovL3N1Y3VyZXRva2VuLmdvb2dsZS5jb20vdHJhbnptYXR1LmNvbTpnY21hbmRyb2lkIiwiaXV0aF90aW11IjoxNjY0NDM3Njk3LCJ1c2VyX2lkIjoiaRTRDNkVBQTIzNDgyMUQxMkUwNTMwMTAwMDA3RjI5OEIiLCJzdWIiOiJFNEU2RUZBMjM0ODUxRDEyRTA1MzAxMDAwMDdGMjk4Q4iIsIm1hdCI6MTY2NDQzNzY5NywiZXhwIjoxNjY0NDQxMjk3LCJmaXJlYmFzZSI6eyJpZGVudG10aWVzIjp7fSwic2lnb19pb19wcm92aWR1ciI6ImN1c3RvbSJ9fQ.XMBaw0rqtn10eegLMKEcMbGb9gyJyd7Xj80gfoDHfytbLxe2yfU2Tf3nfVvPhLLNUuekVVRd-JfGcDf9n9cenIPVYjAMy1Psf-k9Xh6U-Nbt4hkFMKK3kZ7eN5ZPLMykTE05_9pb1b3wmmhxjo-qplQdqjqlLBvA6GvHND-rWCy0Rwz0p61D1KbukBTxxnt7WPLt9sve8t20X0R6R053t2SjPaJZZsNo87Abp24F8ISBo1102S40valUG-CVgDTi71DumcC6GdfIwKiaYG84ayo0So_4cU59Ysfs3fBlf2w2jy0ZPBUG-FreOo4A0DyKdrB2HQZP1Mm-TwSnZYA
```

## HEADER: ALGORITHM & TOKEN TYPE

```
{  
  "alg": "RS256",  
  "kid": "585b90b59c6b36d3c90df0e9104453e62f887f77",  
  "typ": "JWT"  
}
```

## PAYLOAD: DATA

```
{  
  "iss":  
    "https://securetoken.google.com/tranzmate.com:gcmandroid",  
  "aud": "tranzmate.com:gcmandroid",  
  "auth time": 1664437697,  
  "user_id": "E4C6EAA234851D12E0530100007F298B",  
  "sub": "E4C6EAA234851D12E0530100007F298B",  
  "iat": 1664437697,  
  "exp": 1664441297,  
  "firebase": {  
    "identities": {},  
    "sign_in_provider": "custom"  
  }  
}
```

# Can We Forge JWT?

PAYLOAD: DATA

E4C6F3B1EFF23008E0530100007FE981



```
{  
  "https://securetoken.google.com/tranzmate.com:gcmandroi  
d",  
  "aud": "tranzmate.com:gcmandroid",  
  "auth_time": 1664437697,  
  "user_id": "E4C6EAA234851D12E0530100007F298B",  
  "sub": "E4C6EAA234851D12E0530100007F298B",  
  "iat": 1664437697,  
  "exp": 1664441297,  
  "firebase": {  
    "identities": {},  
    "sign_in_provider": "custom"  
  }  
}
```



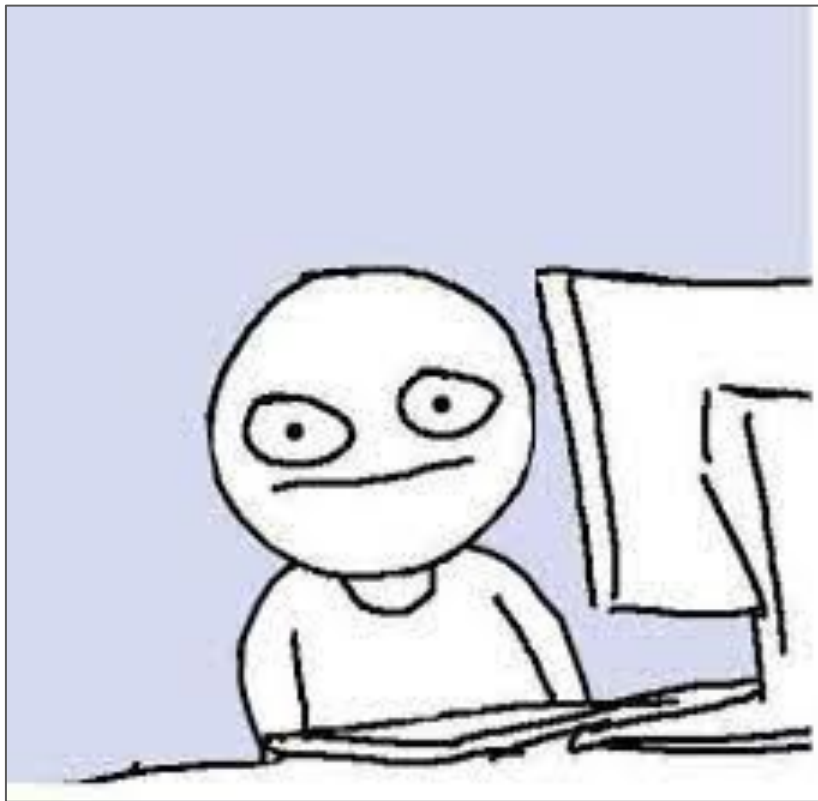
# JWT Validation

```
eyJhbGciOiJSUzI1NiIsImtpZCI6IjU4NWl5MGI  
1OWM2YjM2ZDNjOTBkZjB1OTEwNDQ1M2U2MmY4OD  
dmNzciLCJ0eXAiOiJKV1QiLCJ0eXN1IjoiJodH  
RwczoVL3NlY3VyZXRVa2VuLmdvb2dsZS5jb20vd  
HJhbnptYXR1LmNvbTpnY21hbmRyb2lkIiwiaXVv  
IjoiaHJhbnptYXR1LmNvbTpnY21hbmRyb2lkIiw  
iYXV0aF90aW1lIjoxNjY0NDM3Njk3LCJ1c2VyX2  
1kIjoirTRDNkVBQTIZndG1MUQxMkUwNTMwMTAwM  
DA3RjI5OEIiLCJzdWIiOiJFNEU2RUFBMjM0ODUx  
RDEyRTA1MzAxMDAwMDdGMjk4QjIsIm1hdCI6MTY  
2NDQzNzY5NywiZXhwIjoxNjY0NDQxMjk3LCJmaX  
JlYmFzZSI6eyJpZGVudG10aWVzIjp7fSwic2lnb  
19pb19wcm92aWRlciI6ImN1c3RvbSJ9fQ.XMBaw  
0rqtn10eegLMKCEcMbGb9gyJyd7Xj80gfoDHfyt  
bLxe2yfU2Tf3nfbvVyPh1LNUuekVVRd-  
JfGcDf9n9cenIPVYjAMy1Psf-k9Xh6U-  
Nbt4hkFMKK3kZ7eN5ZPLMykTE05_9pb1b3wwmhx  
jo-qpLQdjqlBvA6GvHND-  
rWCy0RwzOp61D1KbukBTxxnt7WPLt9sve8t20X0  
R6R053t2SjPaJZZsNo87Abp24F8ISBo1L102S40  
valUG-  
CVgDTi71DumcC6GdfIwKiaYG84ayo0So_4cU59Y  
sfs3fBlf2w2jy0ZPBUG-  
FreOo4A0DyKdrB2HQZP1Mm-TwSnZYA
```

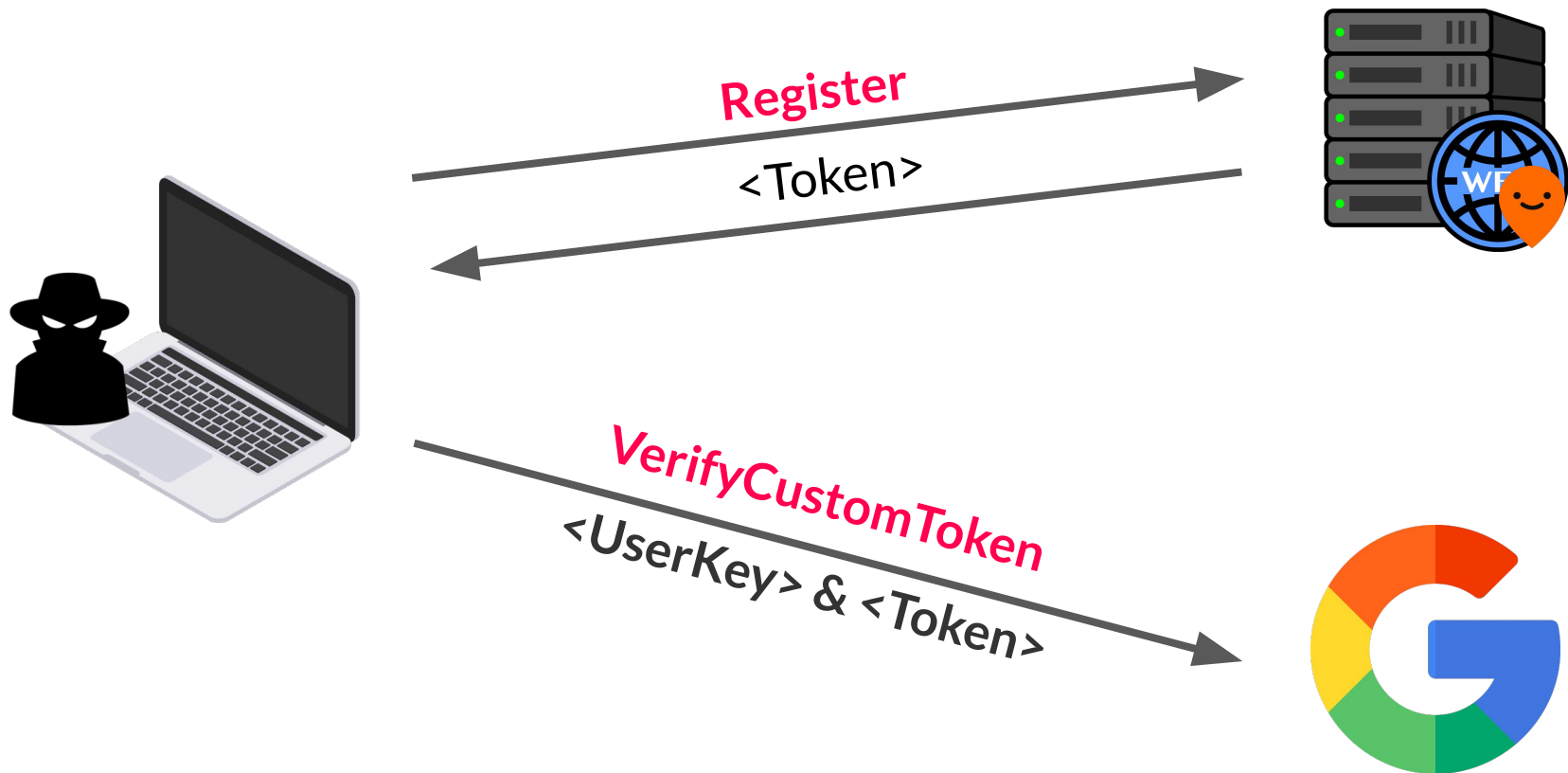
PAYLOAD: DATA

```
{  
  "iss":  
    "https://securetoken.google.com/tranzmate.com:gcmandroi  
d",  
  "aud": "tranzmate.com:gcmandroid",  
  "auth_time": 1664437697,  
  "user_id": "E4C6EAA234851D12E0530100007F298B",  
  "sub": "E4C6EAA234851D12E0530100007F298B",  
  "iat": 1664437697,  
  "exp": 1664441297,  
  "firebase": {  
    "identities": {},  
    "sign_in_provider": "custom"  
  }  
}
```

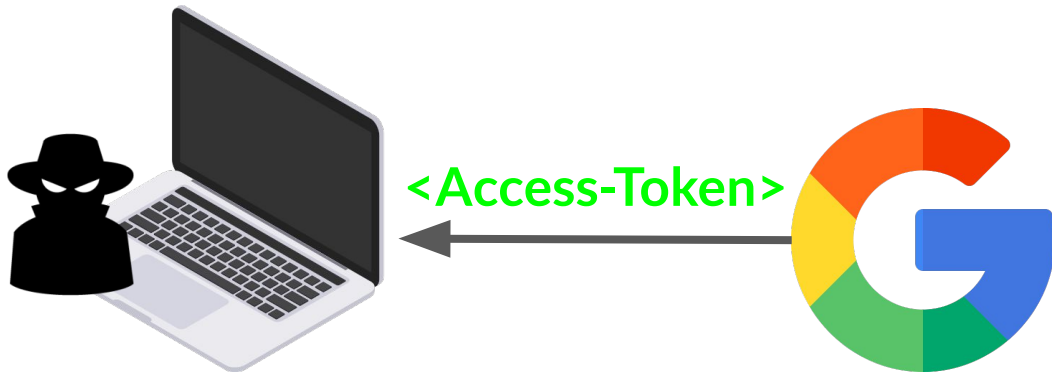
Well.. Now What?



# Getting Access Token



# Elegant Simplicity



# Impersonate Accounts



<AccessToken>



<UserKey>

# Pros & Cons



- Targeted Attack
- Widely Spreaded



- ~~Takes time~~
- ~~Disconnect the account~~
- ~~Requires account phone number~~

# Impersonate Existing Accounts

```
1  [+] [Found Profile] --> E78E43310A806DD9E0530100007F6E7B -> +150
2  [+] [Found Profile] --> E78F48144E6907F6E0530100007F9C84 -> +480
3  [+] [Found Profile] --> E78F56E76ED816FEE0530100007FF967 -> +130
4  [+] [Found Profile] --> E78F685DBB0B2801E0530100007F499E -> +310
5  [+] [Found Profile] --> E78F6C75EA3F2B4AE0530100007FF770 -> +170
6  [+] [Found Profile] --> E78F6AFBF0A629FFE0530100007F76D3 -> +170
7  [+] [Found Profile] --> E78F785DBBE137F6E0530100007FFAA4 -> +160
8  [+] [Found Profile] --> E78F7737FD0D362DE0530100007FA69B -> +130
9  [+] [Found Profile] --> E78FF776D7B93E93E0530100007F9BBF -> +330
10 [+] [Found Profile] --> E7900E50E4B456ECE0530100007FAD43 -> +150
11 [+] [Found Profile] --> E7900035516346D0E0530100007F7250 -> +150
12 [+] [Found Profile] --> E79029DF624C7503E0530100007FC2D8 -> +120
13 [+] [Found Profile] --> E7903443DB317EABE0530100007F58C3 -> +150
14 [+] [Found Profile] --> E7903443DB3E7EABE0530100007F58C3 -> +150
15 [+] [Found Profile] --> E7902662D81A6F08E0530100007F02A1 -> +120
16 [+] [Found Profile] --> E79044E65D490E6CE0530100007F7B91 -> +160
17 [+] [Found Profile] --> E7901BFE1C5F6151E0530100007FD8C3 -> +170
18 [+] [Found Profile] --> E79044E65D710E6CE0530100007F7B91 -> +160
19 [+] [Found Profile] --> E7904119814B0D31E0530100007FEBF0 -> +310
20 [+] [Found Profile] --> E7904A5A6AD5151AE0530100007FA616 -> +160
21 [+] [Found Profile] --> E7903F298C510B5EE0530100007F70B0 -> +440
22 [+] [Found Profile] --> E7906E574A403DBAE0530100007F39BE -> +130
23 [+] [Found Profile] --> E7906E574A413DBAE0530100007F39BE -> +120
24 [+] [Found Profile] --> E79073533AA943EEE0530100007FFEFD -> +190
25 [+] [Found Profile] --> E79074EF650945AAE0530100007FA733 -> +310
26 [+] [Found Profile] --> E79073533ADB43EEE0530100007FFEFD -> +320
```



# PII Database Of The Caught Accounts

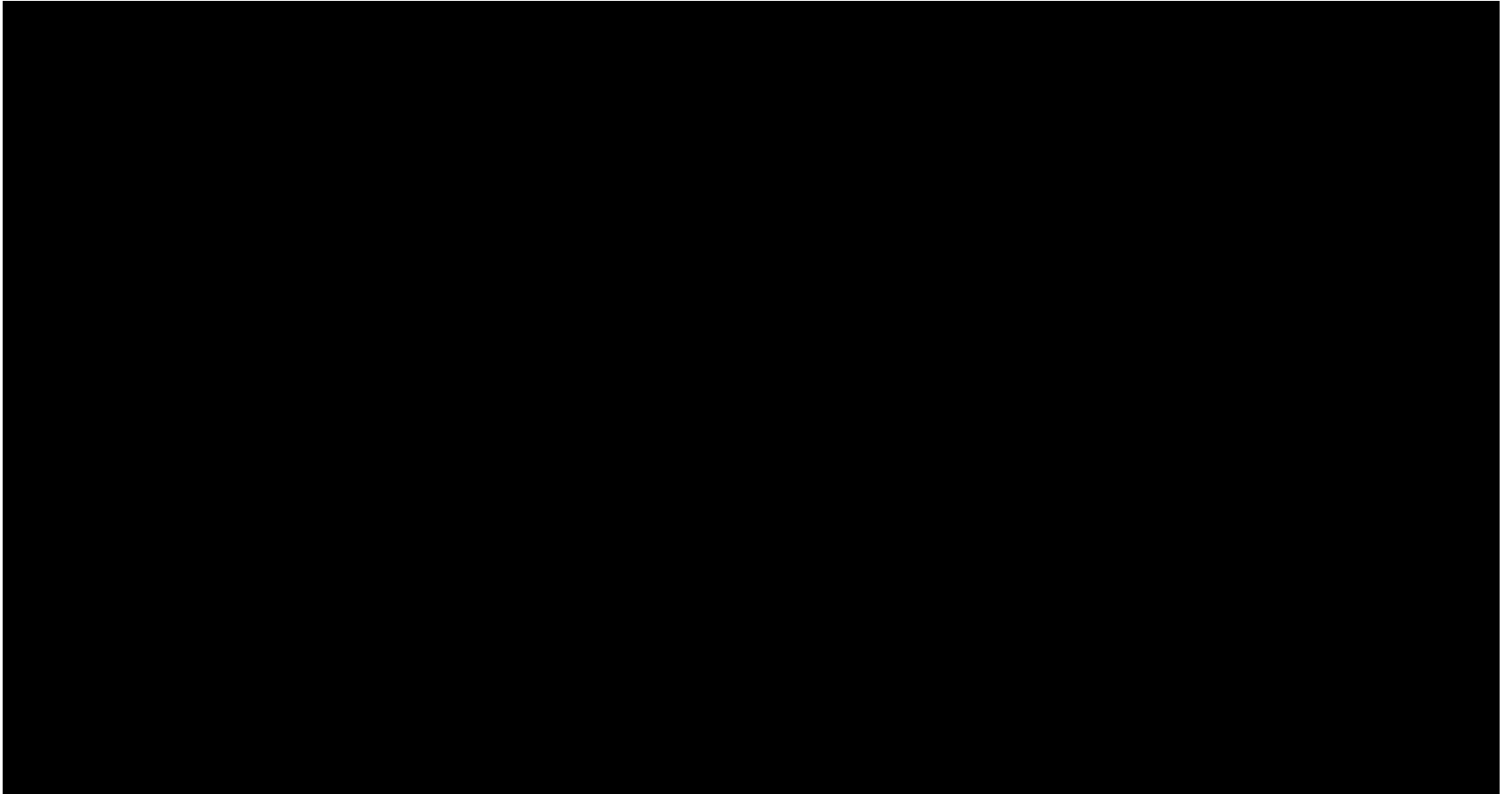
|    | user_key                         | firstname א1 | lastname | email         | bday   | id     | phone  | address |
|----|----------------------------------|--------------|----------|---------------|--------|--------|--------|---------|
|    | Filter                           | Filter       | Filter   | Filter        | Filter | Filter | Filter | Filter  |
| 1  | E4C7A1C3F8A32CDBE0530100007F95B2 | תמימה        |          | 73@gmail.com  | NULL   | 3201   | +9725  | NULL    |
| 2  | E4C787660FE86DF8E0530100007F913F | תומר         |          | 7@gmail.com   | NULL   |        | +9725  | NULL    |
| 3  | E4C7EAC0A80850E8E0530100007FE3DC | תהילה        |          | 7@gmail.com   | NULL   |        | +9725  | NULL    |
| 4  | E4C7310C5E87342DE0530100007FCAC9 | שרון         |          | 7@gmail.com   | NULL   |        | +9725  | NULL    |
| 5  | E4C77BA1C46954FFE0530100007F79EA | שרון         |          | 7@mail.com    | NULL   |        | +9725  | NULL    |
| 6  | E4C7E7CD39A34AF0E0530100007F3928 | שירה         |          | 72@gmail.com  | NULL   |        | +9725  | NULL    |
| 7  | E4C784BA511E69DCE0530100007F32FF | שושנה        |          | 7@gmail.com   | NULL   |        | +9725  | NULL    |
| 8  | E4C7EAC0A7CD50E8E0530100007FE3DC | קימ          |          | 7@gmail.com   | NULL   |        | +9725  | NULL    |
| 9  | E4C735E9204E401EE0530100007F4D93 | קטרינה       |          | 708@gmail.com | NULL   |        | +9725  | NULL    |
| 10 | E4C7CD24CAB70EFC0530100007FFB35  | קובי         |          | 7@walla.com   | NULL   |        | +9725  | NULL    |
| 11 | E4C735E92010401EE0530100007F4D93 | פזית         |          | 71@gmail.com  | NULL   |        | +9725  | NULL    |
| 12 | E4C735E92065401EE0530100007F4D93 | עמית         |          | 77@gmail.com  | NULL   |        | +9725  | NULL    |
| 13 | E4C7AF6B18BB4916E0530100007F8807 | עמית         |          | 7@mail.com    | NULL   |        | +9725  | NULL    |
| 14 | E4C710A4B53A6CE1E0530100007FB373 | עטרה         |          | 73@gmail.com  | NULL   |        | +9725  | NULL    |



# Fun Fact



# Bonus Demo



# Takeaways

- Increase awareness to security measures
- A researcher's perspective

## Vendor Response

We would like to thank SafeBreach for their collaboration on this issue. Moovit has always been committed to protecting user data and takes all reports of security threats seriously. The vulnerabilities were fixed and no customer action is required. As for the QR code, Moovit-Pango follows Israel's MOT rules and guidelines for implementation, and the MOT is aware of the issue.





[https://github.com/SafeBreach-Labs/moovit\\_api\\_scripts/tree/main](https://github.com/SafeBreach-Labs/moovit_api_scripts/tree/main)

# Credits



**Shmuel Cohen**

Security Researcher @ SafeBreach Labs



# Thank You!

Omer Attias  
omer.attias@safebreach.com



Q&A